

NETWORKING THREATS, ASSESSMENTS, AND DEFENSES

After completing this module, you should be able to do the following:

- 1 Describe the different types of networking-based attacks
- 2 List the different network assessment tools
- 3 Explain how physical security defenses can be used

Front-Page Cybersecurity

What would you think if the CEO of Apple said, “Nobody really wants to hack us.”? Or if Google posted on its website, “Attackers aren’t interested in targeting us.” Or the president of Amazon said, “We’re not on any attacker’s radar screen.”

In today’s cybersecurity environment, it would be surprising—probably shocking—to hear people say that attackers are not interested in them. But that’s exactly what happened recently. Could it be true that attackers are not interested in a particular company? Or does the CEO of the company not understand cybersecurity?

A new startup called View manufactures and installs “smart windows” that automatically adjust to sunlight and glare. The blue-tinted windows are expensive: they cost about five times as much as traditional glass windows. However, View windows have several advantages. They reduce cooling costs by blocking heat from sunlight and they can eliminate the need for blinds or window treatments. If a criminal breaks one of the windows, police can immediately be notified. Finally, View windows allow more people to fit into a building. Because View windows reduce glare and heat from the sun, employees can be seated in areas that they could not normally use. One organization installing View windows will be able to place the same number of employees in one-third of the space.

All View windows are interconnected. They are attached to the organization’s local area network (LAN), allowing them to be accessed over the Internet. In fact, each View window has its own IP address. Users can control the windows via a smartphone app.

The View CEO recently said about the company’s windows, “The good news is the window’s not that interesting to hack.”

Most security professionals would strongly disagree with the View CEO. In fact, View windows are interesting to attackers for three reasons.

1. *Entry point into the owner’s corporate network.* Internet of Things (IoT) devices, such as View windows, are the target of attackers because the devices lack security. The same week the View CEO made his bold statement, the Microsoft Threat Intelligence Center said state actors working for the Russian government were using printers, video decoders, and similar IoT devices as a beachhead or entry point to penetrate targeted computer networks. “These devices became points of ingress from which the actor established a presence on the network and continued looking for further access,” Microsoft

said. In other words, IoT devices with little or no security allowed an attacker an entry point into the network. Attackers could then pivot to move through the network in search of higher-privileged accounts that would grant access to higher-value data. In the latest attack referenced by Microsoft, after gaining access to the IoT devices, the threat actors ran *Tcpdump*, a program often used by security personnel to assess network security by sniffing network traffic on local subnets. They also dropped a simple shell script that allowed them to stay on the network for an extended period of time. An analysis of network traffic showed the IoT devices were communicating with an external command and control (C&C) server.

2. *Attack point against other networks.* For several years, threat actors have compromised unprotected IoT devices and then gathered them into a botnet. The botnets attacked other devices or networks. Most notably, IoT-based botnets have been used to launch distributed denial of service or DDoS attacks. A company with View windows installed could find that the windows are a launching point for other attacks.
3. *Backflow into View's own network.* View requires that all its windows have remote connectivity to the company's headquarters so that View can "commission, configure, monitor, and maintain the system." The product documentation lists options for allowing remote access, ranging from "Firewall via DMZ" and "Firewall via Port Mapping" to "Firewall with VPN Access" and other options. However, an attacker who can circumvent these protections can "backflow" into the View network. Because the windows are remotely connected to View's own network, an attacker could compromise a View window belonging to another company and then sneak into the View network. In this way, View windows could allow an attacker entry into View's network.

Despite the statement from the CEO of View that "The good news is the window's not that interesting to hack," the bad news is that View windows are very interesting to hack. The worse news may be that the View CEO is evidently not taking these risks seriously.

Whereas technology devices—including smartphones, tablets, and laptop computers—usually receive all the praise for ushering the world into a new and exciting era, in reality, the invisible network that is connecting the devices should be receiving an equal share of adoration. Imagine a smartphone that cannot connect to a network to receive messages or link to websites but instead can use only what is contained on the smartphone. Most users would quickly dump an unconnected smartphone in the nearest trash bin. The connectivity through networks is what has made today's devices revolutionary.

Invisible networks can link a device to a virtually unlimited volume of information for research. They can also support relationships between people who are separated by hundreds of feet or thousands of miles. E-commerce through networks makes it possible to perform nearly any real-world task online, including retail shopping, banking, real estate transactions, airline bookings, and movie streaming. Networks have empowered today's technology devices to create our digital revolution.

However, networks have also introduced new issues surrounding privacy, trust, and reliability and are responsible for the explosive growth of cybersecurity attacks. They have opened the door for threat actors to reach across the world to invisibly and instantaneously launch attacks on any device connected to the network. Just as users can surf the web without openly identifying themselves, attackers can use this anonymity to cloak their identity and prevent authorities from finding and prosecuting them.

This module begins a study of network attacks and defenses. First, the module explores common attacks that are launched against networks today. Then it looks at tools for assessing and defending networks. Finally, it examines physical security defenses for protecting network technology devices.

ATTACKS ON NETWORKS

CERTIFICATION

1.3 Given a scenario, analyze potential indicators associated with application attacks.

1.4 Given a scenario, analyze potential indicators associated with network attacks.

3.1 Given a scenario, implement secure protocols.

Threat actors place a high priority on targeting networks in their attacks. Exploiting a single network vulnerability can expose hundreds or thousands of devices. Several types of attacks target a network or a process that relies on a network, including interception attacks, Layer 2 attacks, DNS attacks, distributed denial of service attacks, and malicious coding and scripting attacks.

Interception Attacks

Some attacks are designed to intercept network communications. Three of the most common interception attacks are man-in-the-middle, session replay, and man-in-the-browser attacks.

Man-in-the-Middle (MITM)

Suppose that Angie, a high school student, is in danger of receiving a poor grade in math. Her teacher, Mr. Ferguson, mails a letter to Angie's parents requesting a conference regarding her performance. However, Angie waits for the mail and retrieves the letter from the mailbox before her parents come home. She forges her parent's signature on the original letter declining a conference and mails it to her teacher. Angie also replaces the real letter with a counterfeit pretending to be from Mr. Ferguson that compliments Angie on her math work. The parents read the fake letter and tell Angie they are proud of her, while Mr. Ferguson is puzzled that Angie's parents are not concerned about her grades.

Angie has conducted a type of **man-in-the-middle (MITM)** attack. In an MITM, a threat actor is positioned in a communication between two parties, as shown in Figure 8-1. Neither of the legitimate parties is aware of the presence of the threat actor and communicate freely, thinking they are talking only to the authentic party. The goal of an MITM attack is to eavesdrop on the conversation or impersonate one of the parties.

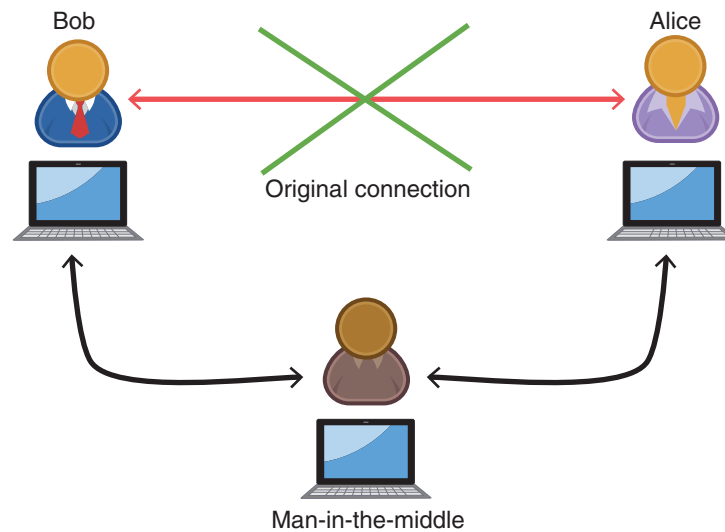


Figure 8-1 MITM attack

A typical MITM attack has two phases. The first phase is intercepting the traffic. A common form of interception is for the threat actor to pretend to be an approved web application by altering packet headers in an IP address. When users attempt to access a URL connected to the application, they are instead sent to the attacker's website.

The second phase is to decrypt the transmissions. An attacker could send a fake digital certificate associated with a compromised application to the victim's computer to trick the computer into verifying the authenticity of the application. The attacker can then access any data entered by the victim.

Session Replay

A *replay* attack is a variation of an MITM attack. Whereas an MITM attack alters and then sends the transmission immediately, a replay attack makes a copy of the legitimate transmission before sending it to the recipient. This copy is used later when the MITM "replays" the transmission.

NOTE 1

Each time a user visits a website, the web server issues a new session ID that usually remains active as long as the browser is open. In some instances, after several minutes of inactivity, the server may generate a new session ID. Closing the browser terminates the active session ID, and it should not be used again.

A specific type of replay attack is a **session replay** attack, which involves intercepting and using a *session ID* to impersonate a user. A session ID is a unique number that a web server assigns a specific user for the duration of the user's visit (session). Most servers create complex session IDs by using the date, time of the visit, and other variables such as the device IP address, email address, username, user ID, role, privilege level, access rights, language preferences, account ID, current state, last login, session timeouts, and other internal session details. Session IDs are usually at least 128 bits in length and hashed using a secure hash function such as SHA-256.

Session IDs can be contained as part of a URL extension, by using hidden form fields in which the state is sent to the client as part of the response and returned to the server as part of a form's hidden data, or through cookies. A sample session ID is *fa2e76d49a0475910504cb3ab7a1f626d174d2d*.

Threat actors use several techniques for stealing an active session ID. These include network attacks (hijacks and altered communication between two users) and endpoint attacks (cross-site scripting, Trojans, and malicious JavaScript coding). Once a session ID has been successfully stolen, a threat actor can impersonate the user.

Man-in-the-Browser (MITB)

Like an MITM attack, a **man-in-the-browser (MITB)** attack intercepts communication between parties to steal or manipulate the data. Whereas an MITM attack occurs between two endpoints—such as between two laptops or a user's computer and a web server—an MITB attack occurs between a browser and the underlying computer. Specifically, an MITB attack seeks to intercept and then manipulate the communication between the web browser and the security mechanisms of the computer.

An MITB attack usually begins with a Trojan infecting the computer and installing an "extension" into the browser configuration so that opening the browser activates the extension. When a user enters the URL of a site, the extension checks whether the site is targeted for attack. After the user signs in to the site, the extension waits for a specific webpage to be displayed in which the user enters information, such as the account number and password for an online financial institution (a favorite target of MITB attacks). When the user clicks Submit, the extension captures all the data from the fields on the form and may even modify some of the entered data. The browser sends the data to the server, which performs the transaction, generates a receipt, and returns it to the browser. The malicious extension captures the receipt data and modifies it (with the data the user originally entered) so that it appears that a legitimate transaction has occurred.

Threat actors gain several advantages in an MITB attack:

- Most MITB attacks are distributed through Trojan browser extensions, which provide a valid function to the user but also install the MITB malware, making it difficult to recognize that malicious code has been installed.
- Because MITB malware selects websites to target, an infected MITB browser might remain dormant for months until triggered by the user visiting a targeted site.
- MITB software resides exclusively within the web browser, making it difficult for standard antimalware software to detect it.

Layer 2 Attacks

In 1978, the International Organization for Standardization (ISO) released a set of specifications to describe how dissimilar computers could be connected together on a network. The ISO demonstrated that what happens on a network device when sending or receiving traffic can be best understood by portraying this transfer as a series of related steps. The ISO called its work the *Open Systems Interconnection (OSI)* reference model. After a revision in 1983, the OSI reference model is still used today.

The key to the OSI reference model is *layers*. The model separates networking steps into a series of seven layers. Within each layer, different networking tasks are performed that cooperate with the tasks in the layers immediately above and below it. Each layer in the sending device corresponds to the same layer in the receiving device. The OSI model is shown in Figure 8-2.

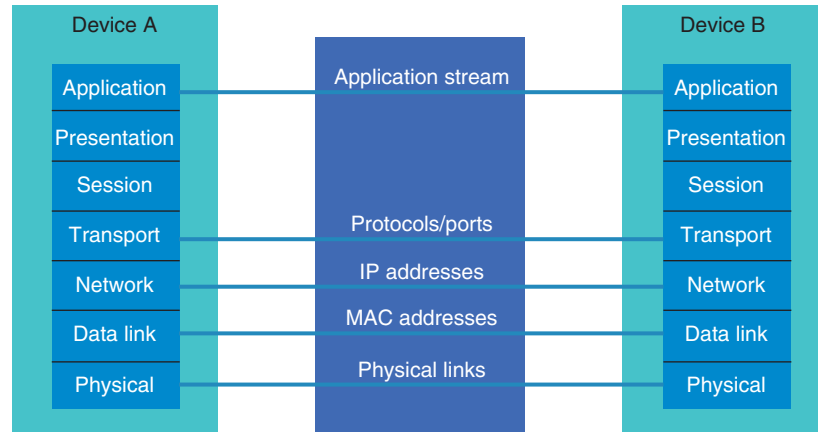


Figure 8-2 OSI model

However, the OSI model was designed so that each layer is compartmentalized: different layers work without the knowledge and approval of the other layers. This means that if one layer is compromised, the other layers are unaware of any problem, which results in the entire communication being compromised.

Layer 2 of the OSI model is particularly weak in this regard and is a frequent target of threat actors. Layer 2, the Data Link Layer, is responsible for dividing the data into packets along with error detection and correction, and performs physical addressing, data framing, and error detection and handling. A compromise at Layer 2 can affect the entire communication, as shown in Figure 8-3.

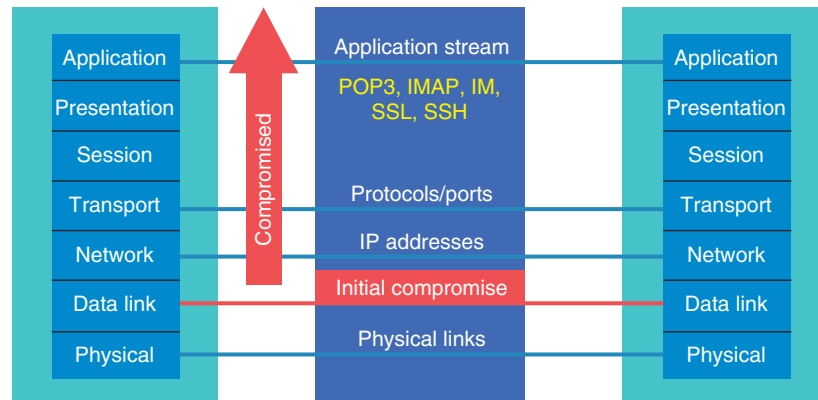


Figure 8-3 Layer 2 compromise

NOTE 2

There is not universal agreement on the usage of the terms *frame*, *packet*, *datagram*, and *segment*. The OSI uses the terms *protocol data unit (PDU)* and *service data unit (SDU)*. Usually, an Ethernet frame is used for Data Link Layer (Layer 2) functions, an IP packet or datagram is at the Network Layer (Layer 3), and a segment is at the Transport Layer (Layer 4). However, the terms are not used consistently. Although some network certification exams do require specific terminology when referring to these data units, the Security+ certification does not. To minimize confusion, the term *packet* is used in the text in a generic sense of a unit of data.

Two common Layer 2 attacks are address resolution protocol poisoning and media access control attacks.

Address Resolution Protocol Poisoning

The TCP/IP protocol suite requires that logical Internet Protocol (IP) addresses be assigned to each device on a network. These addresses can be changed as necessary. However, an Ethernet LAN uses the physical media access control

(MAC) address that is permanently “burned” into a network interface card (NIC) to communicate. How can a physical MAC address be mapped to a logical and temporary IP address?

A device using TCP/IP on an Ethernet network can find the MAC address of another endpoint based on the IP address with the **Address Resolution Protocol (ARP)**. If the IP address for an endpoint is known, but the MAC address is not, the sending endpoint delivers an ARP packet to all devices on the network that in effect says, “If this is your IP address, send me your MAC address.” The endpoint with that IP address sends back a packet with the MAC address so the packet can be correctly addressed. The IP address and the corresponding MAC address are stored in an ARP cache for future reference. In addition, all other endpoints that hear the ARP reply also cache that data.

Threat actors take advantage of a MAC address stored in a software ARP cache to change the data so that an IP address points to a different device. This attack is known as **ARP poisoning** and uses *spoofing*, which is deceiving by impersonating another’s identity. Table 8-1 illustrates the ARP cache before and after an MITM attack using ARP poisoning. Notice that the IP address *192.146.118.4* in Victim 1’s device and *192.146.118.3* in Victim 2’s device now point to different MAC addresses, which would be to the threat actor’s device.

Table 8-1 ARP poisoning attack

Device	IP and MAC address	ARP cache before attack	ARP cache after attack
Threat actor	192.146.118.2 00-AA-BB-CC-DD-02	192.146.118.3=>00-AA-BB-CC-DD-03 192.146.118.4=>00-AA-BB-CC-DD-04	192.146.118.3=> 00-AA-BB-CC-DD-03 192.146.118.4=> 00-AA-BB-CC-DD-04
Victim 1	192.146.118.3 00-AA-BB-CC-DD-03	192.146.118.2=>00-AA-BB-CC-DD-02 192.146.118.4=>00-AA-BB-CC-DD-04	192.146.118.2=> 00-AA-BB-CC-DD-02 192.146.118.4=> 00-AA-BB-CC-DD-02
Victim 2	192.146.118.4 00-AA-BB-CC-DD-04	192.146.118.2=>00-AA-BB-CC-DD-02 192.146.118.3=>00-AA-BB-CC-DD-03	192.146.118.2=> 00-AA-BB-CC-DD-02 192.146.118.3=> 00-AA-BB-CC-DD-02

NOTE 3

ARP poisoning is successful because no authentication procedures verify ARP requests and replies.

Media Access Control Attacks

Besides ARP poisoning, other attacks manipulate MAC addresses through spoofing. The target for these attacks is a network switch.

A network *switch* is a device that connects network devices and, unlike some other network devices, has a degree of “intelligence.” Operating at the Layer 2 Data Link layer, a switch can learn which device is connected to each of its ports. It does so by examining the MAC address of packets it receives and observing at which of the switch’s port that packet arrived. It associates the port with the MAC address of the device connected to the port, storing the information in a *MAC address table*. The switch then knows on which port to forward packets intended for that specific device.

NOTE 4

A switch not only improves network performance by limiting the number of packets distributed but also provides better security. A threat actor who installs software to capture packets on a computer attached to a switch sees only packets that are directed to that device and not those intended for any other network device.

Two common attacks involving spoofing MAC addresses on a switch are MAC cloning and MAC flooding.

MAC Cloning In a **MAC cloning attack**, threat actors discover a valid MAC address of a device connected to a switch. They spoof the MAC address on their device and send a packet onto the network. The switch changes its MAC address table to reflect the new association of the MAC address with the port to which the attackers' device is connected. All packets intended for the victim's device will now be sent to the attackers' device.

MAC Flooding A **MAC flooding attack** is another attack based on spoofing, MAC cloning, and the MAC address table of a switch. A threat actor overflows the switch with Ethernet packets that have been spoofed so that every packet contains a different source MAC address, each appearing to come from a different endpoint. This can quickly consume all the memory (called the *content addressable memory* or *CAM*) for the MAC address table.

Once the MAC address table is full and cannot store any additional MAC addresses, the switch enters a *fail-open* mode and broadcasts frames to all ports. A threat actor can then install software or a hardware device that captures and decodes packets on one client connected to the switch to view all traffic.

NOTE 5

A MAC flooding attack that consumes all the CAM on one switch will ultimately fill the CAM tables of adjacent switches.

DNS Attacks

The predecessor to today's Internet was the network ARPAnet. This network was completed in 1969 and used a 50 Kbps connection to link together single computers located at four sites (the University of California at Los Angeles, the Stanford Research Institute, the University of California at Santa Barbara, and the University of Utah). To reference the computers, each was assigned an identification number. (IP addresses were not introduced until later.) However, as computers were added to the network, it became more difficult for people to accurately recall the identification number of each computer.

The network needed a naming system that would assign computers both numeric addresses and friendlier human-readable names composed of letters, numbers, and special symbols (called a symbolic name). In the early 1970s, each computer site began to assign simple names to network devices and to manage its own *host table* that mapped names to computer numbers. However, because each site attempted to maintain its own local host table, inconsistencies developed between the sites. A standard master host table that could be downloaded to each site was then created. When TCP/IP was developed, the host table concept was expanded to a hierarchical name system for matching computer names and numbers known as the *Domain Name System (DNS)*, which is the basis for **domain name resolution** of names-to-IP addresses used today.

Because of the important role it plays, DNS is the focus of attacks. Like ARP poisoning, a DNS-based attack substitutes a DNS address so that the computer is silently redirected to a different device. A successful DNS attack has two consequences:

- **URL redirection.** The goal of DNS attacks is usually a **URL redirection**: instead of users reaching their intended site, they instead are redirected to another site. The site is often fictitious, one that looks identical to a bank or e-commerce site so that users enter their username, password, and credit card number. The threat actors at the fictitious site capture and use the confidential information.
- **Domain reputation.** Online algorithms are continually evaluating the reputation of webpages, domains, and email services. Consider email reputation: because every email message can be traced to an IP address, and IP addresses gain an IP reputation based on past incidents, an email service that has sent spam or unwanted bulk email earns a low reputation score. An email service might reject email messages with low reputation scores or deliver them more slowly than other email. Similar to an IP reputation, a **domain reputation** can identify a domain used for a distributing malware or launching attacks. A company's competitor could hire a threat actor to use a DNS attack that earns the company a low domain reputation score, thus affecting sales.

Attacks using DNS include DNS poisoning and DNS hijacking.

NOTE 6

On Labor Day in 1969, the first test of ARPAnet was conducted. A switch was turned on, and to almost everyone's surprise, the network worked. Researchers in Los Angeles attempted to type the word *login* on the computer hundreds of miles away at Stanford University. When a user in Los Angeles pressed the letter *L*, it appeared on the screen at Stanford. Next, the letter *O* was pressed, and it too appeared. However, when the third letter, *G*, was typed, the network crashed.

DNS Poisoning

Similar to ARP poisoning, **DNS poisoning** modifies a local lookup table on a device to point to a different domain. Usually, the alternative domain points to a malicious DNS server controlled by a threat actor. The DNS server redirects traffic to a website designed to steal user information or infect the device with malware.

DNS poisoning on the local device involves modifying the local host table. TCP/IP still uses host tables stored on the local device. When a user enters a symbolic name, TCP/IP first checks the local host table to find an entry; if no entry exists, it uses the external DNS system. Attackers can target a local HOSTS file to create new entries that redirect users to a fraudulent site. A sample local host table is shown in Figure 8-4.

127.0.0.1	localhost	
161.6.18.20	www.wku.edu	# Western Kentucky University
74.125.47.99	www.google.com	# My favorite search engine
216.77.188.41	www.att.net	# Internet service provider

Figure 8-4 Sample HOSTS file

NOTE 7

Host tables are stored in the */etc/* directory in UNIX, Linux, and macOS, and they are located in the *Windows\System32\drivers\etc* directory in Windows.

In a DNS poisoning attack, the local HOSTS file contains an entry to a malicious DNS server. This allows the threat actor to control *all* websites that a user attempts to visit. In addition, since most users are unaware of the HOSTS file on their device, DNS poisoning infections can remain undetected for extended periods of time.

NOTE 8

Some governments use DNS poisoning to restrict their citizens from reading what they consider as unfavorable Internet content.

DNS Hijacking

Whereas DNS poisoning attempts to modify the local device HOSTS file, **DNS hijacking** is intended to infect an external DNS server with IP addresses that point to malicious sites. DNS hijacking has the advantage of redirecting *all* users accessing the server.

Instead of attempting to break into a DNS server to change its contents, attackers use a more basic approach. Because DNS servers exchange information among themselves (known as *zone transfers*), attackers attempt to exploit a protocol flaw and convince the authentic DNS server to accept fraudulent DNS entries sent from the attackers' DNS server. If the DNS server does not correctly validate DNS responses to ensure they have come from an authoritative source, it stores the fraudulent entries locally and serves them to users, spreading them to other DNS servers.

The steps in a DNS poisoning attack from attackers who have a domain name of *www.evil.net* with their own DNS server *ns.evil.net* are shown in Figure 8-5:

1. The attackers send a request to a valid DNS server asking it to resolve the name *www.evil.net*.
2. Because the valid DNS server does not know the address, it asks the responsible name server, which is the attackers' *ns.evil.net*, for the address.
3. The name server *ns.evil.net* sends the address of not only *www.evil.net* but also all of its records (a zone transfer) to the valid DNS server, which then accepts them.
4. Any requests to the valid DNS server will now respond with the fraudulent addresses entered by the attackers.

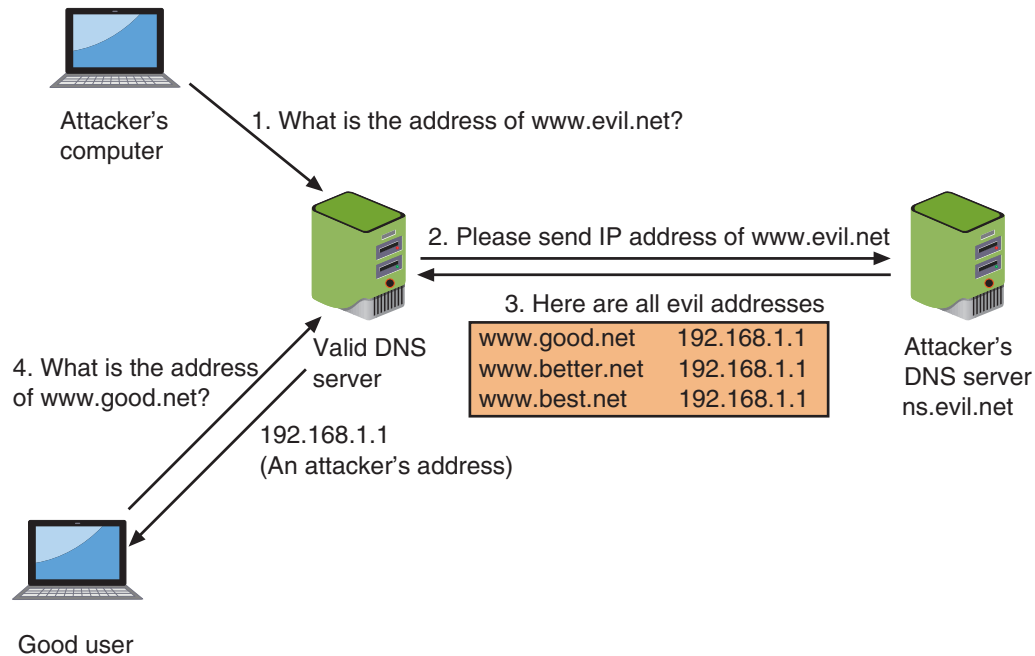


Figure 8-5 DNS server poisoning

NOTE 9

The advantage of a DNS poisoning attack is that all domains one victim uses can be controlled by a threat actor. In contrast, the advantage of a DNS hijacking attack is that although fewer domains are controlled, all users accessing the DNS server are redirected.

Distributed Denial of Service Attack

Suppose Gabe is having a conversation with Cora in a coffee shop when a “flash mob” of friends descends upon them and all talk to Gabe at the same time. He could not continue his conversation with Cora because he is overwhelmed by the number of people talking to him.

In a similar fashion, a technology-based *denial of service (DoS)* attack bombards a system with “bogus” requests, overwhelming the system so that it cannot respond to legitimate requests. DoS attacks today are **distributed denial of service (DDoS)** attacks: instead of only one source making a bogus request, a DDoS involves hundreds, thousands, or even millions of sources producing a torrent of fake requests.

The devices participating in a DDoS attack are infected and controlled by threat actors so that users are completely unaware that their endpoints are part of a DDoS attack. The sources used in DDoS attacks are listed in Table 8-2.

Table 8-2 Sources of DDoS attacks

Name	Source	Example	Target
Network	Computer	Desktop, laptop, tablet	Using Layer 3, it is designed to overwhelm web servers and networks
Application	IoT devices	Baby camera monitors, garage door openers	Focuses on cloud-based resources
Operational Technology (OT)	Endpoints that can be programmed and have an IP address	Automobiles, drones, robots	Using Layer 7, it targets infrastructures like an electrical power grid

NOTE 10

The volume of data directed at a target in a DDoS attack has continued to rise in recent years. The first massive DDoS attack occurred in 2016, when threat actors used 145,607 compromised IoT video cameras and digital video recorders (DVRs) against a French web hosting service, flooding it with 1.1 terabits per second (Tbps) of data. That record was eclipsed in 2018 with an attack of 1.7 Tbps, and again in early 2020, when a DDoS attack registered 2.3 Tbps. It is estimated that a botnet of only one million compromised IoT devices could easily send 4 Tbps in a DDoS attack, which is the equivalent of streaming 800,000 high-definition movies simultaneously.

Malicious Coding and Scripting Attacks

Several successful network attacks come from malicious software code and scripts. These attacks use PowerShell, Visual Basic for Applications, the coding language Python, and the Linux/UNIX Bash.

PowerShell

PowerShell is a task automation and configuration management framework from Microsoft. Initially, PowerShell was a Microsoft Windows component known as Windows PowerShell and was built on the Windows.NET framework (a developer platform that can be used to write apps in specific programming languages). In 2016, it was updated and released both as an open-source and a cross-platform product running on Windows, macOS, and Linux platforms.

Administrative tasks in PowerShell are performed by *cmdlets* (“command-lets”), which are specialized .NET classes that implement a specific operation. PowerShell *providers* give access to data in a data repository, such as the file system or Windows registry. Users and developers can create and add their own cmdlets to PowerShell. PowerShell also provides a hosting application program interface (API) so the PowerShell runtime can even be embedded inside other applications. On the Microsoft Windows platform, PowerShell has full access to a range of OS components and APIs. It can run locally on an endpoint or across a network accessing other endpoint devices.

The power and reach of PowerShell make it a prime target for threat actors. PowerShell allows attackers to inject code from the PowerShell environment into other processes without first storing any malicious code on the hard disk. Commands can then be executed while bypassing security protections and leave no evidence behind. PowerShell can also be configured so that its commands are not detected by antimalware running on the computer. Because most applications flag PowerShell as a “trusted” application, its actions are rarely scrutinized.

CAUTION

These are not vulnerabilities but rather are features of PowerShell as a result of its tight integration with the .NET Framework. PowerShell provides a powerful and easy means to access sensitive elements of an OS and is frequently used by developers and system administrators.

One recent attack illustrates how threat actors can use PowerShell. The attack started with a phishing email containing the subject line “URGENT!” and an Excel attachment with a malicious embedded script. Once the user opened the attachment and approved the script to run its active content, it decrypted and executed a PowerShell script. The script ran with the PowerShell parameters *ExecutionPolicyByPass* (allow the PowerShell script to run despite any system restrictions), *WindowStyleHidden* (run the script quietly without any notification to the user), and *NoProfile* (do not load the system’s custom PowerShell environment).

Visual Basic for Applications (VBA)

Visual Basic for Applications (VBA) is an event-driven Microsoft programming language. VBA allows developers and users to automate processes that normally would take multiple steps or levels of steps. It can be used to control many tasks of the host application, including manipulating user interface features such as toolbars, menus, forms, and dialog boxes.

VBA is built into most Microsoft Office applications (Word, Excel, and PowerPoint, for example) for Windows and Apple macOS platforms. It is also included in select non-Microsoft products, such as AutoCAD, CorelDraw, and LibreOffice. VBA can even control one application from another application using Object Linking and Embedding (OLE) automation. For example, VBA can automatically create a Microsoft Word report from data in a Microsoft Excel spreadsheet. The VBA development environment is shown in Figure 8-6.

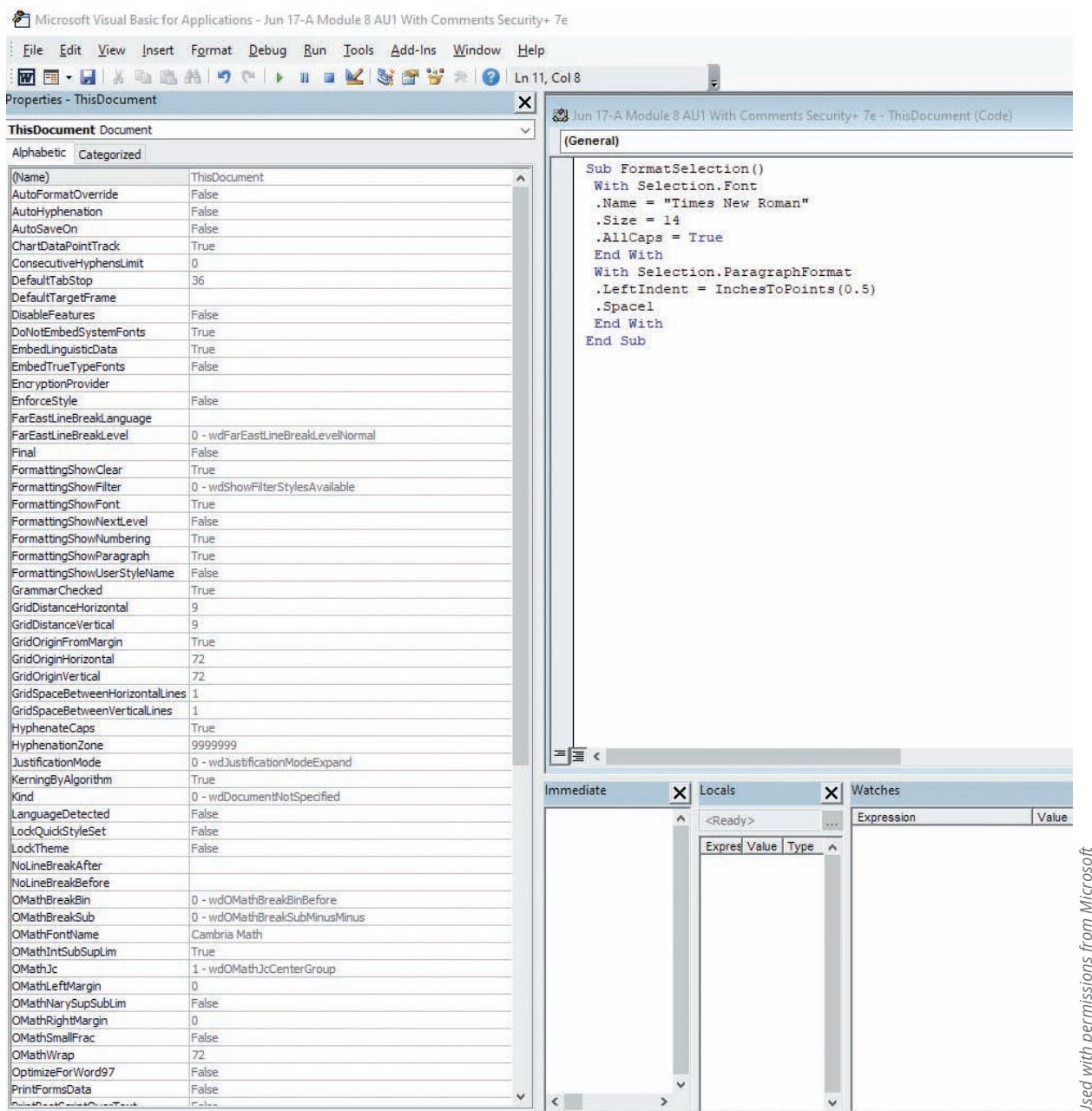


Figure 8-6 VBA development environment

VBA is most often used to create **macros**. A macro is a series of instructions that can be grouped together as a single command. Macros are used to automate a complex task or a repeated series of tasks. Macros are generally written using VBA, are stored within the user document (such as in an Excel .xlsx worksheet or Word .docx file), and can be launched automatically when the document is opened.

Although macros date back to the late 1990s, they continue to be a key attack vector. Microsoft has reported that 98 percent of all Office-targeted threats are a result of macro-based malware, and it has warned users that Office macros, particularly in Excel, are still used to compromise Windows systems.¹ Due to the impact of macro malware, Microsoft has implemented several protections:

- **Protected View.** *Protected View* is a read-only mode for an Office file in which most editing functions are disabled and macros cannot run. When opened, files will display a Protected View warning message if they are from an Internet site, potentially unsafe location, or another user's OneDrive storage; received as an email attachment; or have active content (macros or data connections).

- *Trusted Documents.* A *trusted document* is a file that contains active content that can open without a warning. Users can access the Office Trust Center to designate files as trusted. However, files opened from an unsafe location cannot be designated as a trusted document. A system administrator can also turn off the ability to designate a trusted document.
- *Trusted Location.* Files retrieved from a *trusted location* can be designated as safe and open in standard rather than Protected View. It is recommended that if a user trusts a file that contains active content, it should be moved to a trusted location instead of changing the default Trust Center settings to allow macros.

! CAUTION

Unless there is a business requirement for macros, support for their use should be disabled across the Microsoft Office suite. If macros are required, only those that have been digitally signed by a trusted publisher should be allowed to run. To prevent users or an adversary from bypassing macro security controls, all support for trusted documents and trusted locations should be disabled. Organizations can disable Trust Center settings and apply macro security controls using Group Policy settings.

Python

Python is a popular programming language that can run on several OS platforms. Python's syntax allows programmers to write code that takes fewer lines than in other programming languages such as Java and C++. Python also supports object-oriented programming. It has a large standard library in which developers can use routines created by other developers.

NOTE 11

Python was created in the late 1980s by a Dutch programmer as a side project during his Christmas vacation.

There are several best practices to follow when using Python so that the code does not contain vulnerabilities. These include using the latest version of Python, staying current on vulnerabilities within Python, being careful when formatting strings in Python, and downloading only vetted Python libraries. (A library is a collection of functions and methods that can perform actions so that the programmer does not have to write the code for it.)

Bash

Bash is the command language interpreter (called the "shell") for the Linux/UNIX OS. *Bash scripting* is using Bash to create a *script* (a script is essentially the same as a program, but it is *interpreted* and executed without the need for it to be first *compiled* into machine language). Exploits have taken advantage of vulnerabilities in Bash. For example, one vulnerability allowed attackers to remotely attach a malicious executable file to a *variable* (a value that changes) that is executed when Bash is invoked.

TWO RIGHTS & A WRONG

1. The goal of an MITM attack is to either eavesdrop on the conversation or impersonate one or both of the parties.
2. A session ID is a unique number that a web browser assigns for the duration of that user's visit.
3. In a MAC cloning attack, a threat actor will discover a valid MAC address of a device connected to a switch, spoof that MAC address on his device, and send a packet onto the network.

See Appendix B for the answer.

TOOLS FOR ASSESSMENT AND DEFENSE

✓ CERTIFICATION

4.1 Given a scenario, use the appropriate tool to assess organizational security.

Several assessment tools determine the strength of a network. Other tools can be used to create a stronger network defense. Both types of tools can be categorized into network reconnaissance and discovery tools, Linux file manipulation tools, scripting tools, and packet capture and replay tools.

Network Reconnaissance and Discovery Tools

Some network reconnaissance and discovery tools are command-line utilities that are part of multiple OSs (sometimes with slight variations in their names or different switches or parameters), while others function under only a single OS. These tools are listed in Table 8-3.

Table 8-3 OS network reconnaissance and discovery tools

Name and OS	Description	Important switches or parameters
tracert (Windows) tracert (Linux)	Shows the details about the path a packet takes from a computer or device to a destination	<i>-d</i> (Displays the route using numeric addresses and prevents tracert from resolving IP addresses to hostnames for a faster display) <i>-h hops</i> (Specifies the maximum number of hops while searching for the target)
nslookup (Windows) dig (Linux)	A DNS diagnostic utility; can be used in interactive mode but the non-interactive version of nslookup is easier and therefore is used more often	<i>host</i> (Look up the host using the default server) <i>host [server]</i> (Look up the host using the specified server) <i>-server</i> (Launch interactive mode using the server)
ipconfig (Windows) ifconfig (Linux)	Displays network configuration information such as the IP address, network mask, and gateway for all physical and virtual network adapters	<i>-all</i> (Displays detailed configuration information about all network interfaces) <i>-release [adapter]</i> (Terminates the DHCP lease on the specified adapter or on all interfaces) <i>-displaydns</i> (Displays the contents of the DNS resolver cache)
ping (Windows, Linux)	Tests the ability of the source computer to reach a specified destination computer; commonly used to verify that a computer can communicate over a network with another computer or network device	<i>-t</i> (Force the target to respond until pressing Ctrl+C) <i>-a</i> (Resolve the hostname of an IP address target) <i>-i TTL</i> (Set the Time to Live (TTL) value up to 255) <i>-R</i> (Trace the round-trip path) <i>-r count</i> (Specify number of hops between computer and the target computer)
netstat (Windows, Linux)	Provides detailed information about current network connections as well as network connections for the Transmission Control Protocol (TCP), network interfaces, and routing tables	<i>-a</i> (All active connections and the ports that the computer is listening on) <i>-e</i> (Ethernet data such as number of bytes and packets sent and received) <i>-g</i> (Multicast group membership data) <i>-n</i> (Active TCP connections with addresses and port numbers displayed numerically)
pathping (Windows)	A combination of ping and tracert that will test the connection to each hop.	<i>-q</i> (Limit number of queries) <i>-n</i> (Prevents resolving hostnames)
route (Linux)	Displays and manipulates IP routing table to create static routes to specific hosts	<i>-n</i> (Display numerical addresses) <i>gw gateway</i> (Route packets via gateway)
curl (Linux)	Transfers data to or from a server	<i>-o filename</i> (Save downloaded file with filename) <i>-C -</i> (Resume interrupted download)
hping (Linux)	Sends custom TCP/IP packets	<i>-i interval</i> (Wait <i>interval</i> seconds between sending packets)

Network reconnaissance and discovery tools from third parties are listed in Table 8-4.

Table 8-4 Third-party OS network reconnaissance and discovery tools

Name	Source	Description
theHarvester	Kali Linux	Provides information about email accounts, user names, and hostnames/subdomains from different public sources
dnsenum	Kali Linux	List DNS information of a domain
sn1per	XeroSecurity	Penetration testing tool
Cuckoo	Cuckoo	Automated malware analysis system
Nessus	Tenable	Vulnerability assessment tool
scanless	Vesche	Tool for using websites to perform port scan
nmap	Nmap	Network discovery and security auditing

Linux File Manipulation Tools

Text files are a fundamental element in the Linux OS. Because virtually all configuration files in Linux are text files, changing the configuration of a security application involves modifying the text configuration file. Thus, managing Linux security, applications, and the OS itself demands excellent text manipulation skills. Table 8-5 lists several Linux text file manipulation tools that are part of the Linux OS.

Table 8-5 Linux text file manipulation tools

Tool name	Description	Example
head	Display the first 10 lines of a file	<i>head etc/snort/snort.conf</i>
tail	Display the last 10 lines of a file	<i>tail etc/snort/snort.conf</i>
cat	Display an entire file	<i>cat etc/snort/snort.conf</i>
grep	Search for keyword	<i>grep apache1</i>
chmod	Change file permissions	<i>chmod 774 rules</i>
logger	Add content to syslog file	<i>logger comment</i>

Scripting Tools

Scripting tools are used to create scripts that facilitate tasks. PowerShell is one of the most powerful scripting tools, and Python can also be used to create scripts. Scripts can also be created when using Secure Shell (SSH), which is used to access remote computers.

NOTE 12

SSH is covered in Module 7.

Another tool that supports scripting is [OpenSSL](#), a cryptography library that offers open source applications of the TLS protocol. It was first released in 1998 and is available for Linux, Windows, and macOS platforms. OpenSSL allows users to perform various SSL-related tasks, including CSR (Certificate Signing Request), private key generation, and SSL certificate installation.

Packet Capture and Replay Tools

Collecting and analyzing data packets that cross a network can provide valuable information. Packet analysis typically examines the entire contents of the packet, which consists of the header information and the payload. However, because all the information needed is rarely contained in a single packet, packet analysis examines multiple packets—often hundreds and even thousands of them—to piece together the information.

NOTE 13

Some common uses of packet analysis include troubleshooting network connectivity (determine packet loss, review TCP retransmission, and create graphs of high latency packet responses), examining Application Layer sessions (captured packets can be used to view a full HTTP session for both requests and responses, view Telnet session commands and responses, and even read email traffic), and solving DHCP issues (examine DHCP client broadcasts, view DHCP offers with addresses and options, observe client requests for an address, and see the server's acknowledgment of the request).

Packet analysis can also be used extensively for security. It can detect unusual behavior (such as a high number of DNS responses) that could indicate the presence of malware, search for unusual domains or IP address endpoints, and discover regular connections (beacons) to a threat actor's command and control (C&C) server.

Wireshark is a popular GUI packet capture and analysis tool and is shown in Figure 8-7. **Tcpdump** is a command-line packet analyzer. It displays TCP/IP packets and other packets being transmitted or received over a network. It runs on UNIX and Linux operating systems, and various forks of it are available for Windows computers. However, the output from Tcpdump can be voluminous and difficult to parse. **Tcpreplay** is a tool for editing packets and then "replaying" the packets back onto the network to observe their behavior.

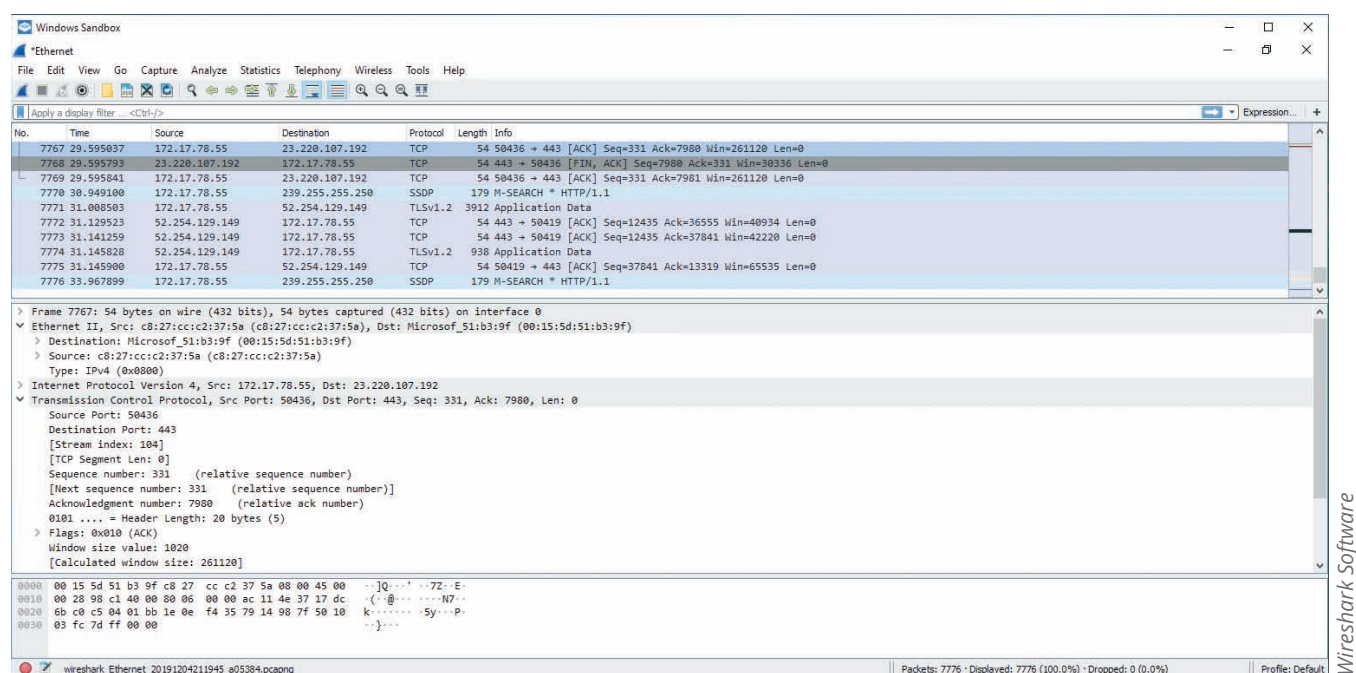


Figure 8-7 Wireshark packet capture and analysis tool

NOTE 14

Several switches are available for Tcpdump. A complete list of Tcpdump switches is available at www.tcpdump.org/manpages/tcpdump.1.html.

TWO RIGHTS & A WRONG

1. The tools `tracert` (Windows) and `traceroute` (Linux) show the details about the path a packet takes from a computer or device to a destination.
2. Nessus is from Kali Linux.
3. The Linux text file manipulation tool `logger` adds content to the syslog file.

See Appendix B for the answer.

PHYSICAL SECURITY CONTROLS

CERTIFICATION

2.7 Explain the importance of physical security controls.

An obvious but often-overlooked consideration when defending a network is physical security: preventing a threat actor from physically accessing the network is as important as preventing the attacker from accessing it remotely. Physical security controls include external perimeter defenses, internal physical security controls, and computer hardware security.

External Perimeter Defenses

Some organizations use **industrial camouflage** in an attempt to make the physical presence of a building as non-descript as possible so that to a casual viewer, the building does not look like it houses anything important. When camouflage is not possible, external perimeter defenses must be used. External perimeter defenses are designed to restrict access to the areas in which equipment is located. This type of defense includes barriers, personnel, and sensors.

Barriers

Different types of passive barriers can restrict people or vehicles from entering a secure area. **Fencing** is usually a tall, permanent structure to keep out unauthorized personnel. It is usually accompanied by **signage** that explains the area is restricted and proper **lighting** so the area can be viewed after dark. However, standard chain link fencing offers limited security because it can easily be circumvented by climbing over it or cutting the links. Most modern perimeter security consists of a fence equipped with other deterrents such as those listed in Table 8-6.

Table 8-6 Fencing deterrents

Technology	Description	Comments
Anticlimb paint	A nontoxic petroleum gel-based paint that is thickly applied and does not harden, making any coated surface very difficult to climb.	Typically used on poles, downpipes, wall tops, and railings above head height (8 feet or 2.4 meters).
Anticlimb collar	Spiked collar that extends horizontally for up to 3 feet (1 meter) from the pole to prevent anyone from climbing it; serves as both a practical and visual deterrent.	Used for protecting equipment mounted on poles like cameras or in areas where climbing a pole can be an easy point of access over a security fence.
Roller barrier	Independently rotating large cups (diameter of 5 inches or 115 millimeters) affixed to the top of a fence prevents the hands of intruders from gripping the top of a fence to climb over it.	Often found around public grounds and schools where a nonaggressive barrier is important.
Rotating spikes	Installed at the top of walls, gates, or fences; the tri-wing spike collars rotate around a central spindle.	Designed for high-security areas; can be painted to blend into fencing.

Like fencing, a **barricade** is generally designed to block the passage of traffic. However, barricades are most often used for directing large crowds and are generally not designed to keep out individuals. This is because barricades are usually not as tall as fences and can easily be circumvented by climbing over them. A **bollard** is a short but sturdy

vertical post that is used as a vehicular traffic barricade to prevent a car from ramming into a secured area. A pair of bollards is pictured in Figure 8-8.



Figure 8-8 Bollards

Personnel

Whereas barriers act as passive devices to restrict access, personnel are considered active security elements. Unlike passive devices, personnel can differentiate between an intruder and someone looking for a lost pet and then decide when it is necessary to take appropriate action.

Human **security guards** who patrol and monitor restricted areas are most often used as an active security defense. In settings that require a higher level of protection, two security guards may be required. This prevents one security guard who has been compromised (through bribery, threats, or other coercion) from participating in an attack, such as allowing malicious actors entrance through a locked door. Using two security guards is called **two-person integrity/control**.

NOTE 15

Most of the major heists involving the theft of large amounts of cash or precious jewels have been the result of an inside employee of a bank, airport warehouse, or other facility participating in the theft.

Some guards are responsible for monitoring activity captured by video surveillance cameras that transmit a signal to a specific and limited set of receivers called **closed circuit television (CCTV)**. Some CCTV cameras are fixed in a single position pointed at a door or a hallway, while other cameras resemble a small dome and allow guards to move the camera 360 degrees for a full panoramic view. High-end video surveillance cameras only record when they detect movement (**motion recognition**), while others can identify a suspicious object such as a backpack left in a chair and sound an alert (**object detection**). Increasingly, drones, also called unmanned aerial vehicles (UAVs), include cameras for monitoring activity.

NOTE 16

When guards actively monitor a CCTV, it is a preventive measure: any unauthorized activity seen on video surveillance results in the guard taking immediate action by going to the scene or calling for assistance. When a guard does not actively monitor a CCTV, the video is recorded and, if a security event occurs, the recording is examined later to identify the culprit.

Robot sentries that patrol and use CCTV with object detection are increasingly being used in public areas. Figure 8-9 shows a robot sentry. Armed robberies, burglaries, and hit-and-run incidents have been solved by data recorded by a robot sentry.



Figure 8-9 Robot sentry

A **receptionist** who staffs a public reception area can also provide a level of active security. Public reception areas are an often-overlooked risk: once visitors are in the reception area, they are already inside the facility beyond external barriers. The receptionist's duty should be to observe and interact appropriately with the public so that potential malicious actors feel they are always being observed. This means receptionists should not have additional clerical duties beyond maintaining a **visitor log** or record (either paper or electronic) of those individuals granted access; otherwise, the receptionists will be distracted from their primary duty.

NOTE 17

Other precautions that should be taken in a public reception area include anchoring furnishings and wall hangings so they cannot be picked up and thrown or used as weapons. The reception room should not be used for mail deliveries, as an employee entrance, or a designated escape route. Receptionists should be able to observe visitors before they enter the reception room and electrically lock out suspicious persons. Receptionists should not be expected to physically intercept or impede a real or perceived attacker but, instead, call for help.

Sensors

With human personnel, an incident may occur during a lapse of attention by a security guard. To supplement the work of security guards, **sensors** can be placed in strategic locations to alert guards by generating an audible **alarm** of an unexpected or unusual action. Table 8-7 lists different types of sensors.

Table 8-7 Sensors

Name	Usage	Description
Motion detection	Can determine an object's change in position in relation to its surroundings.	Passive and active infrared light sensors; can be accurately placed by using sensor cards that can safely locate optical beams invisible to human eye.
Noise detection	Can detect a suspicious noise.	Microphones that turn on when the sensor is using noise-activated technology.
Temperature detection	Will detect a sudden increase or decrease in temperature or the temperature of an object in relation to its surroundings.	A thermal camera can be used to determine if a person is lurking in a dark room.
Moisture detection	Can detect water leaks, dampness, or increased moisture levels.	Often used to detect location of a leak from a water pipe.
Proximity	A sensor that detects the presence of an object ("target") when the target enters the sensor's field.	Depending on the type of proximity sensor, sound, light, infrared radiation (IR), or electromagnetic fields may be utilized by the sensor to detect a target.

Internal Physical Security Controls

External perimeter defenses are designed to keep an intruder from entering a campus, building, or other area. If unauthorized personnel defeat external perimeter defenses, they should next face internal physical access security, such as locks, secure areas, and protected cable distribution. In addition, fire suppression is considered an internal physical control.

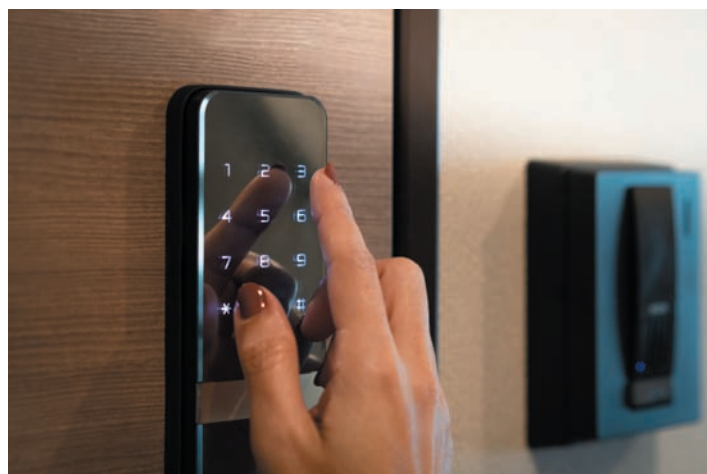
Locks

A variety of locks can restrict access. **Physical locks** that require a key or other device to open doors or cabinets are the most common types of physical locks.

NOTE 18

The categories of commercial door locks include storeroom (the outside is always locked, entry is by key only, and the inside lever is always unlocked), classroom (the outside can be locked or unlocked, and the inside lever is always unlocked), store entry double cylinder (includes a keyed cylinder in both the outside and inside knobs so that a key in either knob locks or unlocks both at the same time), and communicating double cylinder lock (includes a keyed cylinder in both outside and inside knobs, and the key unlocks its own knob independently).

However, physical locks that use keys can be compromised if the keys are lost, stolen, or duplicated. Keys distributed to multiple users to access a single locked door increases the risk of a key being compromised. A more secure option is to use an **electronic lock**, as shown in Figure 8-10. Electronic locks use buttons that must be pushed in the proper sequence to open the door. An electronic lock can also be programmed to maintain a record of when the door was opened and by which code and to allow someone's code to be valid only at specific times. Growing in popularity are *smart locks* that use a smartphone that sends a code via wireless Bluetooth to open the door, and *fingerprint locks* that have a pad that scans a user's fingerprint.

**Figure 8-10** Electronic lock

A problem with an electronic lock is that someone can watch a user enter the code on a physical keypad by shoulder surfing or even detect fingerprint “smudges” on keys to uncover the code. One brand of electronic lock mitigates this weakness by using a virtual screen that substitutes physical buttons with four circles. Each circle displays the numbers associated with that circle (for example, Circle A may display the digits 1, 2, and 3, while Circle B displays the digits 4, 5, and 6) and the digits are randomly assigned to different circles: Circle A now may be 4, 7, and 0 while later it is 2, 5, and 9. This prevents a shoulder surfer from pressing the same circles to unlock the door.

Secure Areas

In a combat area, a **demilitarized zone (DMZ)** separates two warring nations. In cybersecurity, a DMZ is likewise an area that separates threat actors from defenders (also called a physical **air gap**). Enterprises often have DMZs or **secure areas** in a building or office to separate the secure facilities from unknown and potentially hostile outsiders.

Before electronic security was available, vestibules with two locked doors controlled access to sensitive areas. Individuals would give their credentials to a security officer, who opened the first door to a small room (a vestibule) and asked the individuals to enter and wait while their credentials (usually a **badge** or other token that indicates they have been approved) were checked. If the credentials were approved, the second door would be unlocked; if the credentials were fraudulent, the person would be trapped in the vestibule (a *mantrap*).

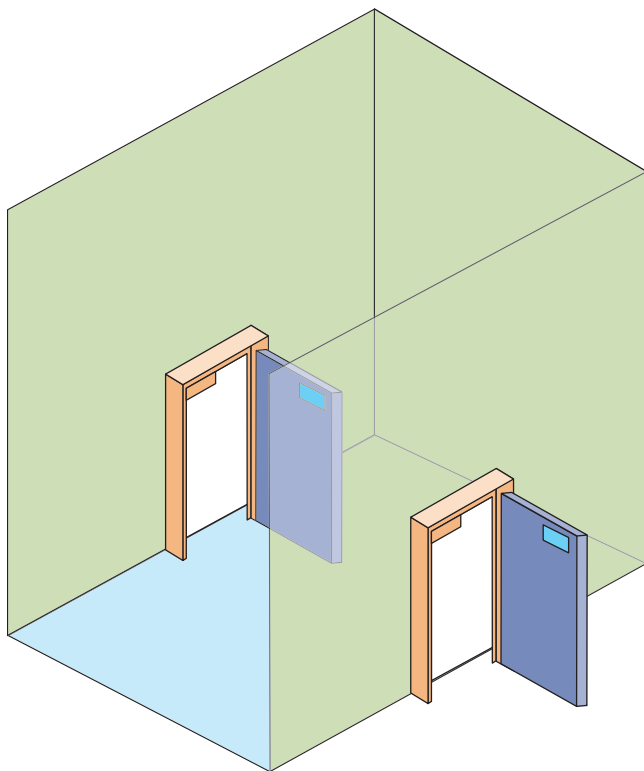


Figure 8-11 Mantrap

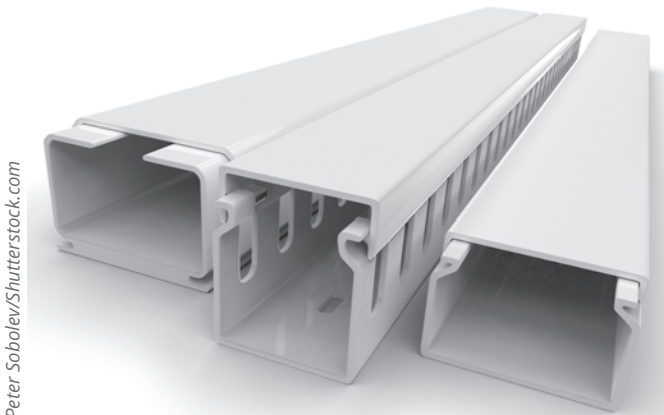
A modern **mantrap** is designed as an air gap to separate a nonsecure area from a secured area. A mantrap device monitors and controls two interlocking doors to a vestibule, as shown in Figure 8-11. When in operation, only one door can be open at any time. Creating a physical air gap, or the absence of any type of connection between the areas, can improve security. Mantraps are used in high-security areas where only authorized persons can enter, such as cash-handling areas and research laboratories.

Another area that must be secured is the *data center* that houses the on-prem network, server, and storage equipment. Because network equipment and servers in a data center generate large amounts of heat, a **hot aisle/cold aisle** layout can reduce the heat by managing air flow. In a data center using a hot aisle/cold aisle layout, the server racks are arranged in alternating rows, with cold air intakes facing one direction and hot air exhausts facing the other direction. The rows composed of the rack fronts are the cold aisles and face air conditioner output ducts. The rows with the backs of the racks where the heated exhausts exit are the hot aisles and generally face the air conditioner return ducts.

Protected Cable Distribution

Cable conduits are hollow tubes that carry copper wire or fiber-optic cables, as shown in Figure 8-12. A **protected cable distribution** is a system of cable conduits used to protect classified information that is being transmitted between two secure areas. PDS is a standard created by the U.S. Department of Defense (DOD).

Two types of PDS are commonly used. In a *hardened carrier PDS*, the data cables are installed in a conduit constructed of special electrical metallic tubing or similar



Peter Sobolev/Shutterstock.com

Figure 8-12 Cable conduits

material. All the connections between segments are permanently sealed with welds or special sealants. If the hardened carrier PDS is buried underground, such as running between buildings, the carrier containing the cables must be encased in concrete, and any manhole covers that give access to the PDS must be locked down. A hardened carrier PDS must be visually inspected on a regular basis.

An alternative to a hardened carrier PDS is an *alarmed carrier PDS*. In this type of PDS, the carrier system is deployed with specialized optical fibers in the conduit that can sense acoustic vibrations that occur when an intruder attempts to gain access to the cables, which triggers an alarm. The advantages of an alarmed carrier PDS are that it provides continuous monitoring, eliminates the need for periodic visual inspections, allows the carrier to be hidden above the ceiling or below the floor, and eliminates the need for welding or sealing connections.

Fire Suppression

Damage inflicted as a result of a fire is a constant threat to persons as well as property. **Fire suppression** includes the attempts to reduce the impact of a fire.

In a data center that contains electronic equipment, using water or a handheld fire extinguisher is not recommended because it can contaminate the equipment. Instead, stationary fire suppression systems are integrated into the building's infrastructure and release fire suppressant. The systems can be classified as dry chemical systems that disperse a fine, dry powder over the fire or clean agent systems that do not harm people, documents, or electrical equipment in the room. Clean agents can extinguish a fire by reducing heat, removing or isolating oxygen, or inhibiting the chemical reaction.

Computer Hardware Security

Computer hardware security is the physical security that specifically involves protecting endpoint hardware, such as laptops that can easily be stolen. Most portable devices (as well as many expensive computer monitors) have a special steel bracket security slot built into the case. A **cable lock** can be inserted into the security slot of a portable device and rotated so that the cable lock is secured to the device, as illustrated in Figure 8-13. The cable can then be connected to an immovable object.

For storage, a laptop can be placed in a **safe** or a **vault**, which is a ruggedized steel box with a lock. Some offices have safes in employee cubicles for the users to lock up important papers when away from their desks, even for a short period of time. The sizes typically range from small (to accommodate one laptop) to large (for multiple devices). Safes and cabinets also can be prewired for electrical power as well as wired network connections. This allows the laptops stored in the locking cabinet to charge their batteries and receive software updates while not in use.

Computer systems, printers, and similar digital electronic devices emit electromagnetic fields, which can result in interference, called *electromagnetic interference (EMI)*. Electromagnetic spying, or picking up electromagnetic fields and reading the data that is producing them, is a risk.

NOTE 19

For a fire to occur, four entities must be present at the same time: a type of *fuel* or combustible material, sufficient *oxygen* to sustain the combustion, enough *heat* to raise the material to its ignition temperature, and a chemical *reaction* that is the fire itself. The first three factors form a fire triangle; to extinguish a fire, any one of these elements must be removed.



Figure 8-13 Cable lock

O. Bellini/Shutterstock.com

NOTE 20

In mid-2020, researchers revealed a new technique for long-distance eavesdropping they call “lamphone.” Anyone with a computer, telescope, and a \$400 electrooptical sensor can listen to any sounds in a room hundreds of feet away in real time simply by observing the minuscule vibrations those sounds create on the glass surface of a light bulb inside the room. By measuring the tiny changes in light output from the bulb that those vibrations cause, the researchers show that a spy can pick up sound clearly enough to discern the contents of conversations or even recognize a piece of music.

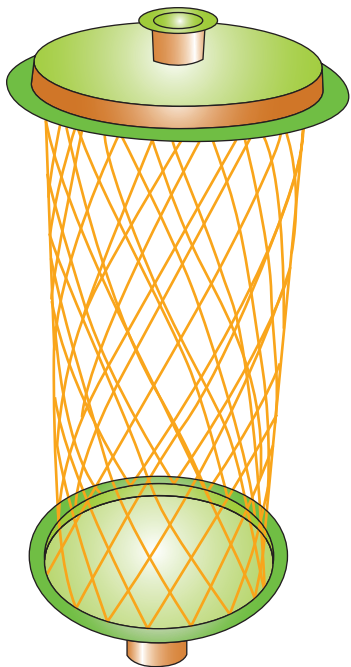


Figure 8-14 Faraday cage

One means of protecting against EMI is a **Faraday cage**, a metallic enclosure that prevents the entry or escape of an electromagnetic field. A Faraday cage, consisting of a grounded, fine-mesh copper screening, as shown in Figure 8-14, is often used for testing in electronic labs. In addition, lightweight and portable *Faraday bags* made of special materials can shield cell phones and portable computing devices such as tablets and notebook computers. Faraday bags are often used in crime scene investigations. Phones, tablets, or laptops found on scene are placed in Faraday bags, thus eliminating inbound and outbound signals and preventing the devices from being remotely wiped of evidence.

TWO RIGHTS & A WRONG

1. A barricade is a short but sturdy vertical post that is used as a vehicular traffic barricade to prevent a car from ramming into a secured area.
2. An electronic lock is a combination lock that uses buttons that must be pushed in the proper sequence to open the door.
3. A DMZ is also called a physical air gap.

See Appendix B for the answer.

VM LAB

You're now ready to complete the live, virtual machine labs for this module. The labs can be found in the Practice It folder in each MindTap module.

SUMMARY

- Some attacks are designed to intercept network communications. A man-in-the-middle (MITM) attack intercepts legitimate communication and forges a fictitious response to the sender or eavesdrops on the conversation. A session replay attack intercepts and uses a session ID to impersonate a user. A man-in-the-browser (MITB) attack occurs between a browser and the underlying computer. An MITB attack seeks to intercept and then manipulate the communication between the web browser and the security mechanisms of the computer.
- Layer 2 of the OSI model is particularly weak and is a frequent target of threat actors. ARP poisoning changes the ARP cache so the corresponding IP address is pointing to a different computer. In a MAC cloning attack, threat actors will discover a valid MAC address of a device connected to a switch and then spoof that MAC address on their device and send a packet onto the network. The switch will change its MAC address table to reflect this new association of that MAC address with the port to which the attackers' device is connected. In a MAC flooding attack, threat actors will overflow the switch with Ethernet packets that have been spoofed so that every packet contains a different source MAC address, each appearing to come from a different endpoint. This can quickly consume all the memory for the MAC address table and will enter a fail-open mode and function like a network hub, broadcasting frames to all ports. Threat actors could then install software or a hardware device that captures and decodes packets on one client connected to the switch to view all traffic.
- DNS poisoning modifies a local lookup table on a device to point to a different domain, which is usually a malicious DNS server controlled by a threat actor that will redirect traffic to a website designed to steal user information or infect the device with malware. DNS hijacking is intended to infect an external DNS server with IP addresses that point to malicious sites. A distributed denial of service (DDoS) attack involves a device being overwhelmed by a torrent of fake requests so that it cannot respond to legitimate requests for service.

- Several successful network attacks come from malicious software code and scripts. PowerShell is a task automation and configuration management framework from Microsoft. The power and reach of PowerShell make it a prime target for threat actors who use it to inject malware. Visual Basic for Applications (VBA) is an “event-driven” Microsoft programming language that is used to automate processes that normally would take multiple steps or levels of steps. VBA is most often used to create macros. A macro is a series of instructions that can be grouped together as a single command. Macros are still used to distribute malware. Python is a popular programming language that can run on several different OS platforms. There are several “best practices” to follow when using Python so that the code does not contain vulnerabilities. Bash is the command language interpreter (called the “shell”) for the Linux/UNIX OS. Bash scripting is using Bash to create a script (a script is essentially the same as a program, but it is interpreted and executed without the need for it to be first compiled into machine language). Exploits have taken advantage of vulnerabilities in Bash.
- There are several different assessment tools for determining the strength of a network. Text files are a fundamental element when using the Linux OS. Because virtually all configuration files in Linux are text files, changing the configuration of a security application involves modifying the text configuration file. Thus, being able to manipulate text is an important skill in managing Linux security, as well as other applications and even the OS itself. There are a variety of different tools that can be used to create scripts that facilitate tasks. One tool that supports scripting is OpenSSL, a cryptography library that offers open source applications of the TLS protocol.
- Collecting and analyzing data packets that cross a network can provide a wealth of valuable information. Packet analysis can also be used extensively for security. Wireshark is a popular GUI packet capture and analysis tool. Tcpdump is a command-line packet analyzer. Tcpreplay is a tool for editing packets and then “replaying” the packets back onto the network to observe their behavior.
- An often-overlooked consideration when defending a network is physical security: preventing a threat actor from physically accessing the network is as important as preventing the attacker from accessing it remotely. External perimeter defenses are designed to restrict access to the areas in which equipment is located. Fencing is usually a tall, permanent structure to keep out unauthorized personnel. It is usually accompanied by signage that explains the area is restricted and proper lighting so the area can be viewed after dark. A barricade is generally designed to block the passage of traffic. A bollard is a short but sturdy vertical post that is used to as a vehicular traffic barricade to prevent a car from ramming into a secured area.
- While barriers act as passive devices to restrict access, personnel are considered active security elements. Human security guards who patrol and monitor restricted areas are most often used as an active security defense. Using two security guards is called two-person integrity/control. Some guards are responsible for monitoring activity captured by video surveillance cameras that transmit a signal to a specific and limited set of receivers called closed circuit television (CCTV). High-end video surveillance cameras only record when they detect movement (motion recognition) while others can identify a suspicious objective and sound an alert. Increasingly, drones/unmanned aerial vehicles (UAV) with cameras are also being used for monitoring activity. Robot sentries that patrol and use CCTV with object detection are increasingly being used in public areas. A receptionist who staffs a public reception area can also provide a level of active security. To supplement the work of security guards, sensors can be placed in strategic locations to alert guards by generating an audible alarm of an unexpected or unusual action.
- In the event that unauthorized personnel defeat external perimeter defenses, they should then face internal physical access security. A variety of types of locks can be used to restrict access. Physical locks that require a key or other device to open doors or cabinets are the most common types of physical locks. However, physical locks that use keys can be compromised if the keys are lost, stolen, or duplicated. A more secure option is to use an electronic lock. These locks use buttons that must be pushed in the proper sequence to open the door.
- A demilitarized zone (DMZ) is an area that separates threat actors from defenders (also called a physical air gap). A mantrap is designed as an air gap to separate a nonsecure area from a secured area. A mantrap device monitors and controls two interlocking doors to a vestibule. A protected cable distribution is a system of cable conduits used to protect classified information that is being transmitted between two secure areas. Damage inflicted as a result of a fire is a constant threat to persons as well as property. Fire suppression includes the attempts to reduce the impact of a fire. In a data center that contains electronic equipment, using a handheld fire extinguisher is not recommended because the chemical contents can contaminate the equipment. Instead, stationary fire suppression systems are integrated into the building’s infrastructure and release fire suppressant in the room.

- A cable lock can be inserted into the security slot of a portable device and rotated so that the cable lock is secured to the device. When storing a laptop, it can be placed in a safe or a vault, which is a ruggedized steel box with a lock. Some offices have safes in employee cubicles for the users to lock up important papers when away from their desks, even for a short period of time. A Faraday cage is a metallic enclosure that prevents the entry or escape of an electromagnetic field.

Key Terms

Address Resolution Protocol (ARP)	hot aisle/cold aisle	protected cable distribution
air gap	hping	proximity
alarm	ifconfig	Python
ARP poisoning	industrial camouflage	receptionist
badge	ipconfig	robot sentries
barricade	lighting	route
Bash	logger	safe
bollard	MAC cloning attack	scanless
cable lock	MAC flooding attack	secure areas
cat	macro	security guards
chmod	man-in-the-browser (MITB)	sensors
closed circuit television (CCTV)	man-in-the-middle (MITM)	session replay
Cuckoo	mantrap	signage
curl	moisture detection	sn1per
demilitarized zone (DMZ)	motion detection	tail
dig	motion recognition	Tcpdump
distributed denial of service (DDoS)	Nessus	Tcpdump
DNS hijacking	netstat	Tcpdump
DNS poisoning	nmap	temperature detection
dnsenum	noise detection	theHarvester
domain name resolution	nslookup	traceroute
domain reputation	object detection	tracert
electronic lock	OpenSSL	two-person integrity/control
Faraday cage	Operational Technology (OT)	URL redirection
fencing	pathping	vault
fire suppression	physical locks	visitor log
grep	ping	Visual Basic for Applications (VBA)
head	PowerShell	Wireshark

Review Questions

- Which attack intercepts communications between a web browser and the underlying OS?
 - Interception
 - Man-in-the-browser (MITB)
 - DIG
 - ARP poisoning
- Calix was asked to protect a system from a potential attack on DNS. What are the locations he would need to protect?
 - Web server buffer and host DNS server
 - Reply referrer and domain buffer
 - Web browser and browser add-on
 - Host table and external DNS server
- What is the result of an ARP poisoning attack?
 - The ARP cache is compromised.
 - Users cannot reach a DNS server.
 - MAC addresses are altered.
 - An internal DNS must be used instead of an external DNS.
- Deacon has observed that the switch is broadcasting all packets to all devices. He suspects

- it is the result of an attack that has overflowed the switch MAC address table. Which type of attack is this?
- MAC spoofing attack
 - MAC cloning attack
 - MAC flooding attack
 - MAC overflow attack
5. Tomaso is explaining to a colleague the different types of DNS attacks. Which DNS attack would only impact a single user?
- DNS hijack attack
 - DNS poisoning attack
 - DNS overflow attack
 - DNS resource attack
6. Proteus has been asked to secure endpoints that can be programmed and have an IP address so that they cannot be used in a DDoS attack. What is the name for this source of DDoS attack?
- Network
 - Application
 - IoT
 - Operational Technology
7. Which of the following is NOT a reason that threat actors use PowerShell for attacks?
- It cannot be detected by antimalware running on the computer.
 - It leaves behind no evidence on a hard drive.
 - It can be invoked prior to system boot.
 - Most applications flag it as a trusted application.
8. What is the difference between a DoS and a DDoS attack?
- DoS attacks are faster than DDoS attacks.
 - DoS attacks use fewer computers than DDoS attacks.
 - DoS attacks do not use DNS servers as DDoS attacks do.
 - DoS attacks use more memory than DDoS attacks.
9. Which of the following is NOT true about VBA?
- It is commonly used to create macros.
 - It is built into most Microsoft Office applications.
 - It is included in select non-Microsoft products.
 - It is being phased out and replaced by PowerShell.
10. Which of the following is NOT a Microsoft defense against macros?
- Protected View
 - Trusted documents
 - Trusted domain
 - Trusted location
11. Theo uses the Python programming language and does not want his code to contain vulnerabilities. Which of the following best practices would Theo NOT use?
- Only use compiled and not interpreted Python code.
 - Use the latest version of Python.
 - Use caution when formatting strings.
 - Download only vetted libraries.
12. What is Bash?
- The command-language interpreter for Linux/UNIX OSs
 - The open source scripting language that contains many vulnerabilities
 - A substitute for SSH
 - The underlying platform on which macOS is built
13. Gregory wants to look at the details about the patch a packet takes from his Linux computer to another device. Which Linux command-line utility will he use?
- tracepacket
 - trace
 - tracert
 - traceroute
14. Which utility sends custom TCP/IP packets?
- curl
 - hping
 - shape
 - pingpacket
15. Which of the following is a third-party OS penetration testing tool?
- theHarvester
 - scanless
 - Nessus
 - snlper
16. Eros wants to change a configuration file on his Linux computer. He first wants to display the entire file contents. Which tool would he use?
- head
 - show
 - display
 - cat
17. Which of the following is a tool for editing packets and then putting the packets back onto the network to observe their behavior?
- Tcpreplay
 - Tcpdump
 - Wireshark
 - Packetdump

18. Estevan has recommended that the organization hire and deploy two security guards in the control room to limit the effect if one of the guards has been compromised. What is Estevan proposing?
- Dual observation protocol (DOP)
 - Compromise mitigation assessment (CMA)
 - Two-person integrity/control
 - Multiplayer recognition
19. Which of the following sensors can detect an object that enters the sensor's field?
- Proximity
 - Field detection
 - IR verification
 - Object recognition
20. Which of the following does NOT describe an area that separates threat actors from defenders?
- DMZ
 - Air gap
 - Secure area
 - Containment space

Hands-On Projects



CAUTION

If you are concerned about installing any of the software in these projects on your regular computer, you can instead use the Windows Sandbox or install the software in the Windows virtual machine created in the Module 1 Hands-On Projects. Software installed within the virtual machine will not impact the host computer.

Project 8-1: DNS Poisoning

Time Required: 20 minutes

Objective: Given a scenario, analyze potential indicators associated with network attacks.

Description: Substituting a fraudulent IP address can be done by either attacking the Domain Name System (DNS) server or the local host table. Attackers can target a local hosts file to create new entries that will redirect users to their fraudulent site. In this project, you add a fraudulent entry to the local hosts file.

- Go to the Western Kentucky University website at **www.wku.edu**.
- Go the website for your school or the business where you work.
- Find the IP address of the website of the school or business. Open a command line and enter **ping name_of_website** or go to **ipaddress.com/ip_lookup/** and enter the domain name to receive the correct IP address.



CAUTION

If your search reveals multiple IP addresses for that website, choose another website that only has a single IP address.

- Verify the IP address of both sites. To reach the Western Kentucky University website by IP address, use your web browser to go to **https://161.6.94.21**.



CAUTION

If your browser displays warning messages when searching by IP address, click through those messages and approve using the IP address.

- Go to the website of your school or business by entering **https://IP_address**.
- Click **Start** and then click **Windows Accessories**.
- Right-click **Notepad**, click **More**, and then select **Run as administrator**. If you receive the message **Do you want to allow this app to make changes to the device?** click **Yes**.

8. Click **File** and then click **Open**. Click the **File Type** arrow to change from **Text Documents (*.txt)** to **All Files (*.*)**.
9. Navigate to the file **C:\Windows\System32\drivers\etc\hosts** and open it.
10. At the end of the file following all hashtags (#) in the first column, enter the IP address of **161.6.94.21**. This is the IP address of Western Kentucky University.
11. Press **Tab** and enter *www.name_of_your_school_or_business*. In this hosts table, the domain name of your school or business is now resolved to the IP address of Western Kentucky University.
12. Click **File** and then click **Save**.
13. Open your web browser and then enter the URL of your school or business. What website appears?
14. Return to the hosts file and remove this entry.
15. Click **File** and then click **Save**.
16. Close all windows.

Project 8-2: ARP Poisoning

Time Required: 25 minutes

Objective: Given a scenario, analyze potential indicators associated with network attacks.

Description: Attackers frequently modify the Address Resolution Protocol (ARP) table to redirect communications away from a valid device to an attacker's computer. In this project, you view the ARP table on your computer and modify it. You will need to have another "victim's" computer running on your network (and know the IP address), as well as a default gateway that serves as the switch to the network.

1. Open a Command Prompt window by right-clicking **Start** and selecting **Windows PowerShell (Admin)**.
2. To view your current ARP table, type **arp -a** and then press **Enter**. The Internet Address is the IP address of another device on the network while the Physical Address is the MAC address of that device.
3. To determine network addresses, type **ipconfig/all** and then press **Enter**.
4. Record the IP address of the default gateway.
5. Delete the ARP table entry of the default gateway by typing **arp -d** followed by the IP address of the gateway, such as **arp -d 192.168.1.1**, and then press **Enter**.
6. Create an automatic entry in the ARP table of the victim's computer by typing **ping** followed by that computer's IP address, such as **ping 192.168.1.100**, and then press **Enter**.
7. Verify that this new entry is now listed in the ARP table by typing **arp -a** and then press **Enter**. Record the physical address of that computer.
8. Add that entry to the ARP table by entering **arp -s** followed by the IP address and then the MAC address.
9. Delete all entries from the ARP table by typing **arp -d**.
10. Close all windows.

Project 8-3: MAC Spoofing

Time Required: 25 minutes

Objective: Given a scenario, analyze potential indicators associated with network attacks.

Description: In a MAC cloning attack, threat actors discover a valid MAC address of a device connected to a switch. They spoof the MAC address on their device and send a packet onto the network. In this activity, you will spoof a MAC address.

1. Go to the Technitium website at **technitium.com/tmac/**. (If you are no longer able to access the program through this URL, use a search engine to search for "Technitium MAC address changer.")
2. Click **Download Now**.
3. Click **Direct Download**.
4. Save the file to your computer, install the application, and then start it.
5. If necessary, click **Yes** to respond to the dialog box.
6. Scroll through the list of network connections on your computer, and then select your Internet connection.

7. Read the information on the **Information** tab.
8. Click **Random MAC Address** to display another MAC address that can be assigned to this device.
9. Click the down arrow in the box below the new random MAC address. Note the long list of different NIC vendors from which a MAC address can be chosen.
10. Click **(2C-30-33) Netgear**.
11. Look at the new MAC address under **Change MAC Address** and note the first three pairs of numbers. What does this correspond to?
12. Click **Why?** next to **Use '02' as first octet of MAC address**.
13. Read the explanation about why 02 should be used as the first octet.
14. If you want to change your MAC address, click **Change Now!** or close the application if you do not want to change the address.
15. How easy was it to spoof a MAC address? How can a threat actor use this in a MAC cloning attack?
16. Close all windows.

Case Projects

Case Project 8-1: DDoS Mitigation

How do organizations attempt to mitigate a sudden DDoS attack directed at their web servers? Use the Internet to research DDoS mitigation techniques, technologies, and third-party entities that provide mitigation services. Write a one-page paper on your research.

Case Project 8-2: DNS Services

Many organizations offer a free domain name resolution service that resolves DNS requests through a worldwide network of redundant DNS servers. The claim is that this is faster and more reliable than using the DNS servers provided by Internet service providers (ISPs). These DNS servers are supposed to improve security by maintaining a real-time blacklist of harmful websites and warning users when they attempt to access a site containing potentially threatening content. The providers also say that using their services can reduce exposure to types of DNS poisoning attacks. Research free DNS services. Identify at least three providers and create a table comparing their features. Are the claims of providing improved security valid? How do they compare with your ISP's DNS service? Write a one-page paper on your research.

Case Project 8-3: DNS-over-HTTPS (DoH)

To protect DNS, some providers are using DNS-over-HTTPS, also called DoH. As its name implies, DoH uses HTTPS instead of HTTP to send DNS queries via an encrypted HTTPS connection (Port 443) rather than sending them in cleartext (Port 53). The encrypted DoH query is sent to a special DoH-resolving server that aggregates all user's DoH queries and then translates them into regular unencrypted DNS queries for processing by DNS servers. However, DoH has become controversial. Why? What are the advantages of DoH? What are its disadvantages? How does it compare with DNS-over-TLS (DoT)? Write a one-page paper on your research.

Case Project 8-4: CCTV Technologies

Research new technologies for CCTV, including motion recognition and object detection. How accurate are the technologies? What are the advantages? What are the disadvantages? Write a one-page paper on your research.

Case Project 8-5: Robot Sentries

Research the Internet regarding robot sentries. Where are they being used? What is the purpose of a robot sentry? What are the risks? What is your projection on the future for robot sentries? Write a one-page paper on your research.

Case Project 8-6: Locks

Lock technology is changing rapidly. Use the Internet to research physical locks, electronic locks, smart locks, and fingerprint locks. Create a table of these types of locks and list their strengths, weaknesses, and costs. Which would you recommend? Why?

Case Project 8-7: Community Site Activity

The Information Security Community Site is an online companion to this textbook. It contains a wide variety of tools, information, discussion boards, and other features to assist learners. Go to **community.cengage.com/infosec2** and click the *Join or Sign in* icon to login, using your login name and password that you created in Module 1. Click **Forums (Discussion)** and click on **Security+ Case Projects (7th edition)**. Read the following case study.

Read again the Front-Page Cybersecurity at the beginning of this module. In addition to the three reasons listed why View windows would be interesting to attackers, can you think of two or more other reasons how attackers (either cybersecurity attackers or physical criminals) could manipulate these windows? Now pretend that you are a security consultant and View is one of your clients. What would you say to the View CEO about his public statement that “The good news is the window’s not that interesting to hack.” Should CEOs first talk with employees before making those statements? Or have the security employees done a poor job in educating the View CEO about cybersecurity risks? Record your answers on the Community Site discussion board.

Case Project 8-8: North Ridge Security

North Ridge Security provides security consulting and assurance services. You have recently been hired as an intern to assist this company.

It’s Your Birthday (IYB)! is a new North Ridge client that creates fun and innovative birthday experiences for clients of all ages. Recently, IYB! decided that the security at its corporate office needed to be addressed after several incidences of unauthorized personnel entering the offices. You are asked to provide information about internal physical security controls as a starting point in the discussion.

1. Create a PowerPoint presentation about internal physical security controls, including what they are, what they can protect, how they should be used, and the various types of controls. Include the advantages and disadvantages of each. Your presentation should contain at least 10 slides.
2. After the presentation, you were asked to follow up about reception areas and mantraps, especially how to configure each. Create a memo communicating which you would recommend and why.

References

1. Thompson, Mia, “How to stay safe from Office macro-based malware with email security,” *Solarwinds MSP*, Feb. 10, 2020, accessed Jun. 17, 2020, www.solarwindsmsp.com/blog/how-stay-safe-office-macro-based-malware-email-security.

NETWORK SECURITY APPLIANCES AND TECHNOLOGIES

After completing this module, you should be able to do the following:

- 1 List the different types of network security appliances and how they can be used
- 2 Describe network security technologies

Front-Page Cybersecurity

One constant across all of the Star Wars films is the use of weapons: lightsabers, blasters, ion cannons, and planetary turbolasers are just a few that are used by both the Rebellion and the Evil Empire. An additional weapon in the Star Wars arsenal did not appear in any film but was extremely important. The weapon kept cyber threat actors from stealing the script as it was developed. As with most Star Wars weapons, it worked.

Protecting new Star Wars scripts is a high-stakes effort. The Star Wars franchise is estimated to have grossed more than \$10 billion since the first movie came out in 1977. The success of the movies shows no signs of diminishing. The latest movie, *Star Wars: The Rise of Skywalker*, has already grossed more than \$1 billion since its release in December 2019. Those involved with the Star Wars films have every incentive to make sure that scripts for future releases are kept secure and are not stolen. A leaked script would spoil the impact of the storyline and affect ticket sales for the movie.

In recent years, attackers have stolen scripts or entire movies from movie studios or their affiliates. In 2017, a group of attackers stole and then leaked the entire fifth season of Netflix's *Orange Is the New Black* videos along with several other productions from Larson Studios, a Hollywood-based audio post-production company. In late 2004, attackers breached Sony security and posted online several unreleased movies, including *Annie*, *Mr. Turner*, *To Write Love on Her Arms*, and *The Interview*.

What weapons has Star Wars used to protect itself from attackers?

Consider the weapon that the writer and director, Rian Johnson, used to protect his script while he was developing *Star Wars: The Last Jedi* from theft.

He used an air gap.

One of the best means of providing security is to completely disconnect a device from any and all networks. Sometimes called an air gap, this method simply means that the device is not connected to a network or anything else. In today's world, it can be cumbersome and inconvenient to have an unconnected device, but it provides a high level of security.

That's exactly what Rian Johnson did. While writing the script, Rian never connected his MacBook Air to any network (either a LAN or the Internet) and never used it for email, online research, or anything else. In fact, his MacBook Air was

only used for one purpose: to write the script. Isolating the laptop meant that no outsiders could get to his script through a network vulnerability. While he was not using it, the MacBook Air was locked securely in a safe at the studios. Rian's air gap weapon worked as expected and the script was never stolen.

Rian did say that his producer had a constant worry. He was terrified that Rian would walk off and leave the MacBook at a coffee shop.

At one time, *information security* and *network security* were virtually synonymous. That was because the network was viewed as the “moat” around which endpoint computers could be kept safe. A secure network was seen as the key to keeping attackers away.

This approach, however, proved to be untenable. Too many entry points allow attackers to circumvent the network and introduce malware. For example, users could insert an infected USB flash drive into their computer, thus installing malware while bypassing the secure network. With computers connected to the unsecure Internet, malware could take advantage of common network protocols, such as Hypertext Transfer Protocol (HTTP), without being detected or blocked by network security appliances.

This is not to say that network security is unimportant. Having a secure network is still essential. Even today, not all applications are designed and written with security in mind, so it falls on the network to provide protection. Network-delivered services can also scale better for larger environments and can complement server and application functionality. Because an attacker who successfully penetrates a computer network can access hundreds or even thousands of endpoints, servers, and storage devices, a secure network defense remains a critical element in any enterprise's overall security plan.

This module explores network security. It investigates how to build a secure network through network security appliances and technologies.

SECURITY APPLIANCES

CERTIFICATION

2.1 Explain the importance of security concepts in an enterprise environment.

3.3 Given a scenario, implement secure network designs.

All modern networks have both standard networking devices (such as switches and routers) and specialized security appliances. Security can be achieved through the appliances that directly address security and by using the security features in standard networking devices. Using both standard networking devices and security appliances can result in a layered security approach, which can significantly improve security. To breach a network with layered security, an attacker must have the tools, knowledge, and skills to break through the various layers.

While it is worthwhile to take advantage of the security features of standard networking devices, several security appliances can be dedicated to protecting a network. These appliances include firewalls, proxy servers, deception instruments, intrusion detection and prevention systems, and network hardware security modules. In addition, these appliances must be properly configured.

NOTE 1

Security appliances are only one element in network security and should not be exclusively relied upon for protection. This can be illustrated through a successful attack on NASA's Jet Propulsion Laboratory (JPL) that resulted in 500 MB of stolen data related to a Mars mission. A 49-page report by the NASA Office of Inspector General (OIG) revealed that although the NASA JPL network had security appliances installed, the point of entry into the network by attackers was a \$35 Raspberry Pi, small enough to fit in your hand, that a JPL employee connected to the JPL network without authorization.

Firewalls

Probably the most misunderstood security appliance is a firewall. Due to the nature of its name (*It's an impenetrable wall!*) and aided by inaccurate portrayals in movies and television, the general public often perceives a firewall as the ultimate security device that blocks anything and everything malicious from entering a network. Unfortunately, this is a wildly inaccurate perception. Firewalls are an important element in network security, but they fall far short of being the ultimate defense. To use them effectively, you should understand the function of firewalls and know the different types of firewalls and specialized firewall appliances.

Firewall Functions

Both national and local building codes require commercial buildings, apartments, and other similar structures to have a *firewall*. In building construction, a firewall is usually a brick, concrete, or masonry wall positioned vertically through all stories of the building. Its purpose is to contain a fire and prevent it from spreading. A computer **firewall** serves a similar purpose: it is designed to limit the spread of malware.

A firewall uses bidirectional inspection to examine both outgoing and incoming network packets. It allows approved packets to pass through but can take different actions when it detects a suspicious packet. The actions are based on specific criteria or rules; these types of firewalls are called *rule-based firewalls*. Firewall rules can contain parameters such as the following:

- **Source address.** The source address is the location of the origination of the packet (where the packet is *from*). Addresses generally can be indicated by a specific IP address or range of addresses, an IP mask, the MAC address, or host name.
- **Destination address.** This is the address the connection is attempting to reach (where the packet is going *to*). Destination addresses can be indicated in the same way as the source address.
- **Source port.** The source port is the TCP/IP port number used to send packets of data. Options for setting the source port often include a specific port number or a range of numbers.
- **Destination port.** This setting gives the port on the remote computer or device that the packets will use. Options are the same as for the source port.
- **Protocol.** The protocol defines the network protocol (such as *TCP*, *UDP*, *TCP or UDP*, *ICMP*, or *IP*) used when sending or receiving packets of data.
- **Direction.** This is the direction of traffic for the data packet (*Incoming*, *Outgoing*, or *Both*).
- **Priority.** The priority determines the order in which the rule is applied.
- **Time.** Rules can be set so they are active only during a scheduled time.
- **Context.** A rule can be created that is unique for specific circumstances (contexts). For example, different rules may be in effect depending on whether a laptop is on-site or is remote (sometimes called **geographical consideration**).
- **Action.** The action setting indicates what the firewall should do when the conditions of the rule are met. Typical firewall rule actions are listed in Table 9-1.

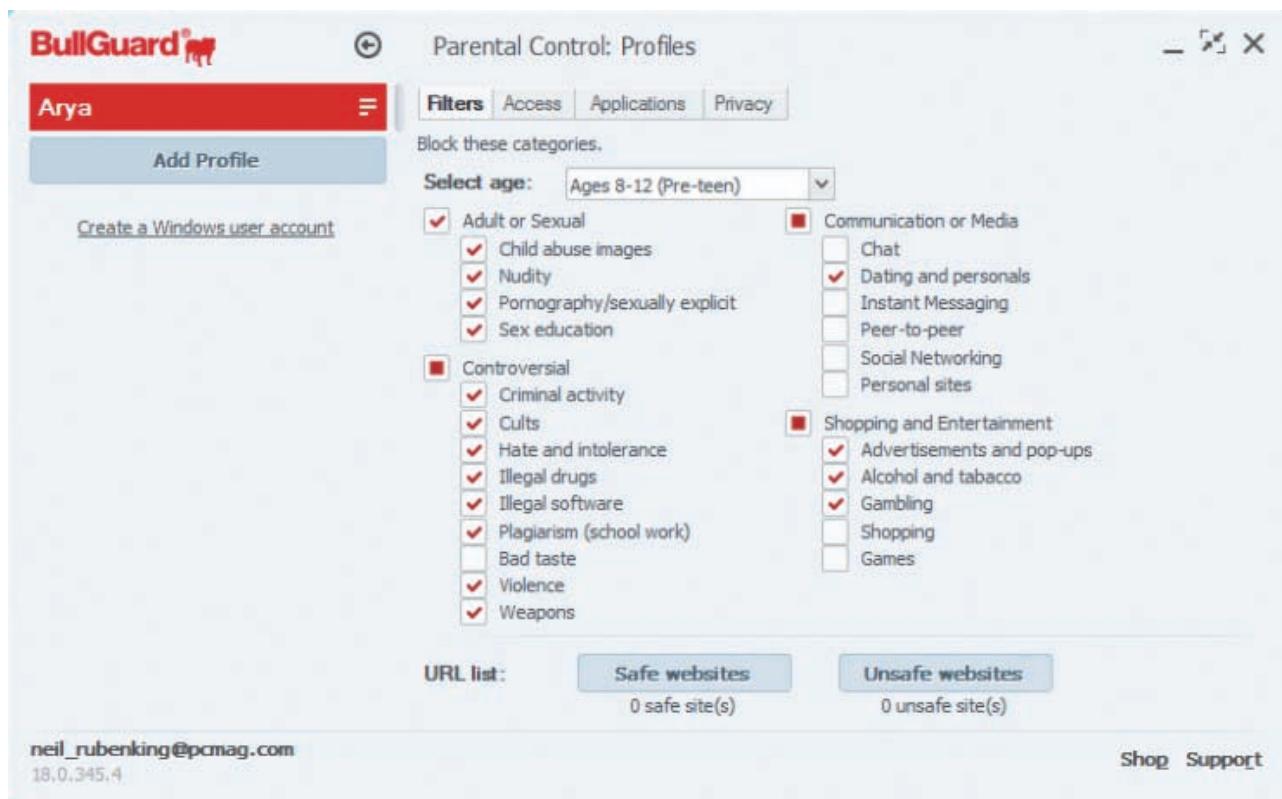
Table 9-1 Typical firewall rule actions

Action	Description	Example	Comments
Allow	Explicitly allows traffic that matches the rule to pass	Permit incoming Address Resolution Protocol (ARP) traffic	Allow implicitly denies all other traffic unless explicitly allowed
Bypass	Allows traffic to bypass the firewall	Bypass based on IP, port, traffic direction, and protocol	Designed for media-intensive protocols or traffic from a trusted source
Deny	Explicitly blocks all traffic that matches the rule	Deny traffic from IP address	Deny generally drops the packet with no return message to the sender
Force Allow	Forcibly allows traffic that would normally be denied by other rules	Useful for determining if essential network services are able to communicate	Traffic will still be subject to inspection by other security appliances
Log Only	Traffic is logged but no other action is taken	Bypass rules do not generate log files but Log Only will	Log Only occurs if the packet is not stopped by a Deny rule or an Allow rule that excludes it

Older firewalls often listed each rule as a separate instruction that was processed in sequence so that firewall rules were essentially *IF-THEN-ELSE* constructions: *IF* these rule conditions are met, *THEN* the action occurs, *ELSE* go on to the next rule. This construction made administrators consider the rules themselves and their sequencing. For example, if Rule #13 allowed an FTP connection to a specific address, but later Rule #27 was added to deny all FTP traffic, then FTP packets meeting Rule #13 would be allowed because it occurred first. More modern firewalls allow a priority order to be created to eliminate the confusion that often surrounded conflicting rules.

A more flexible type of firewall than a rule-based firewall is a *policy-based firewall*. This type of firewall allows more generic statements instead of specific rules. For example, the policy statement *Allow management traffic from trusted networks* could translate into specific rules that allow traffic from *192.2.0.0/24* to *TCP Port 22* and *192.2.100.0/24* to *TCP Port 3389*.

In addition to filtering based on packets, firewalls can also apply **content/URL filtering**. The firewall can monitor websites accessed through HTTP to create custom filtering profiles. The filtering can be performed by assessing webpages by their content category and then creating whitelists and blacklists of specific URLs. This type of filtering is often available with consumer-oriented firewalls and advertised as a parental control feature that is easily configurable, as shown in Figure 9-1.



Source: BullGuard

Figure 9-1 Content/URL filtering

Firewall Categories

The categories of firewalls can be compared as opposites and include the following:

- *Stateful vs. stateless.* **Stateless packet filtering** looks at a packet and permits or denies it based solely on the firewall rules. **Stateful packet filtering** uses both the firewall rules and the state of the connection: that is, did the internal device request this packet? A stateful packet filtering firewall keeps a record of the state of a connection between an internal endpoint and an external device. While a stateless packet filter

firewall might allow a packet to pass through because it met all the necessary criteria (rules), a stateful packet filter would not let the packet pass if that internal endpoint did not first request the information from the external server.

- *Open source vs. proprietary.* Some firewalls are freely available (**open source firewalls**) while other firewalls are owned by an entity that has an exclusive right to them (**proprietary firewalls**). Open source firewalls have been gaining wider acceptance as they incorporate more features and are built on a secure foundation. For example, pfSense is built on the same underlying OS as many commercial products. See Figure 9-2.

Floating LocalNetworks WAN LAN DMZ WAN2 L2TP VPN IPsec OpenVPN											
Rules (Drag to Change Order)											
	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
Remote Administration											
☐	✓	6/803 KiB	IPv4 TCP	RemoteAdmin	*	This Firewall	admin ports	*	none	Allow firewall admin	
VPN Rules											
☐	✓	0/0 B	IPv4 UDP	203.0.113.5	*	WAN address	1195	*	none	OpenVPN from Remote Site 2	
☐	✓	0/0 B	IPv4 UDP	203.0.113.5	*	WAN address	1194 (OpenVPN)	*	none	OpenVPN from Remote Site B	
☐	✓	0/0 B	IPv4 UDP	*	*	WAN address	1194 (OpenVPN)	*	none	Allow traffic to OpenVPN server	
Public Services											
☐	✓	0/0 B	IPv4 TCP	*	*	10.3.0.15	80 (HTTP)	*	none	NAT HTTP to web server	
☐	✓	0/0 B	IPv4 TCP	bob	*	10.3.0.5	22 (SSH)	*	none	NAT Bob - SSH	
☐	✓	0/0 B	IPv4 TCP	sue	*	10.3.0.15	22 (SSH)	*	none	NAT Sue - SSH	
Misc											
☐	✓	0/0 B	IPv4 TCP/UDP	WAN net	*	*	1812 - 1813	*	none	RADIUS from other test firewalls	

Source: pfSense

Figure 9-2 pfSense open source firewall

- *Hardware vs. software.* A **software firewall** runs as a program or service on a device, such as a computer or router. **Hardware firewalls** are specialized separate devices that inspect traffic. Because they are specialized devices, hardware firewalls tend to have more features but are more expensive and can require more effort to configure and manage. However, a disadvantage of a software firewall is that a malware infection on the device on which it is running, such as a computer, could also compromise the software firewall. Whereas a hardware firewall also has underlying software, typically that footprint is smaller (to provide less of a target for attackers) or specialized.
- *Host vs. appliance vs. virtual.* A **host-based firewall** is a software firewall that runs on and protects a single endpoint device (a host). All modern OSs include a host-based firewall. The settings for the Microsoft Windows Defender host-based firewall are shown in Figure 9-3. A closer look at the configuration settings reveals that these firewalls tend to be application-centric: users can create an opening in the firewall for each specific application. This approach is more secure than permanently opening a port in the firewall that always remains open as opposed to a port that is only opened when the application requires it and is then closed. An **appliance firewall** is typically a separate hardware device designed to protect an entire network, as shown in Figure 9-4. A **virtual firewall** is one that runs in the cloud. Virtual firewalls are designed for settings, such as public cloud environments, in which deploying an appliance firewall would be difficult or even impossible.

Help protect your PC with Windows Defender Firewall

Windows Defender Firewall can help prevent hackers or malicious software from gaining access to your PC through the Internet or a network.

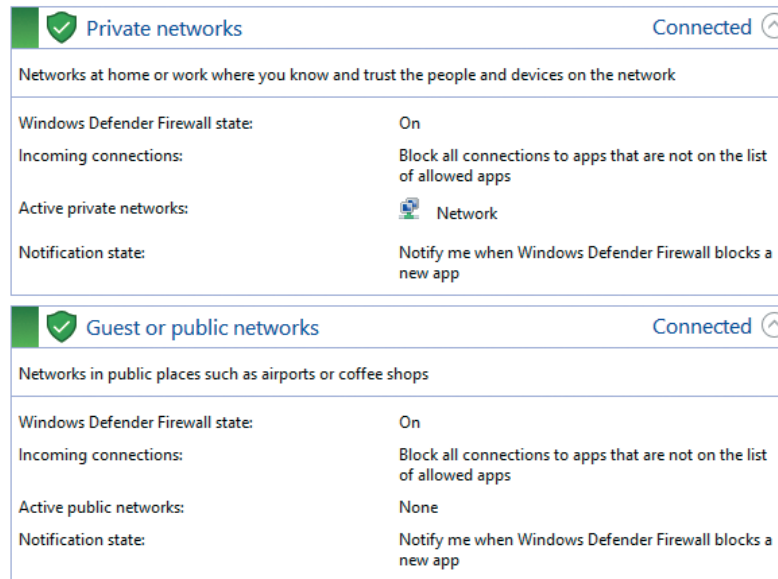


Figure 9-3 Windows host-based firewall

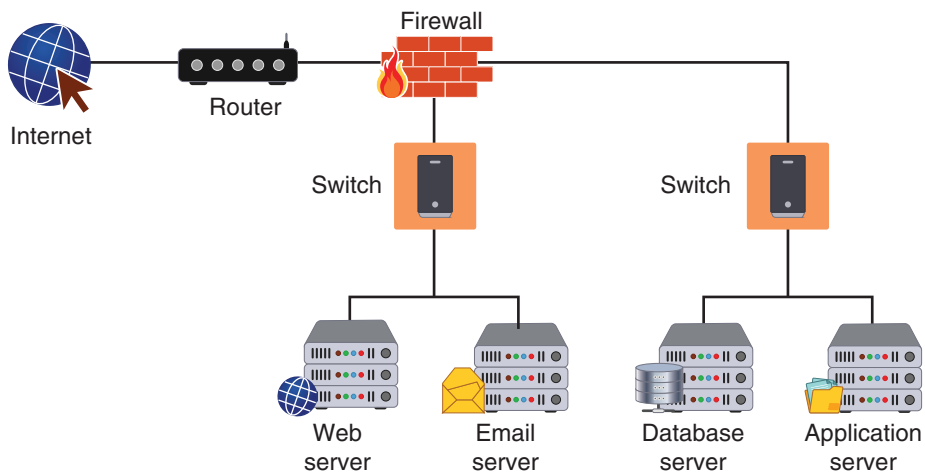


Figure 9-4 Appliance firewall

Specialized Firewall Appliances

Specialized firewall appliances include the following:

- *Web application firewall.* One specialized firewall is a **web application firewall (WAF)** that looks at the applications using HTTP. A web application firewall, which can be a separate hardware appliance or a software plug-in, can block specific websites or attacks that attempt to exploit known vulnerabilities in specific client software and can even block cross-site scripting and SQL injection attacks.
- *Network address translation gateway.* *Network address translation (NAT)* is a technique that allows private IP addresses to be used on the public Internet. It does this by replacing a private IP address with a public IP address. As a packet leaves a network, NAT removes the private IP address from the sender's packet and replaces it with an alias IP public address, and then maintains a record of the substitution. When a packet is returned, the process is reversed. A **network address translation gateway** is a cloud-based technology that performs NAT translations for cloud services. It can also provide a degree of security by masking the IP addresses of internal devices.

- **Next generation firewall.** A **next generation firewall (NGFW)** has additional functionality beyond a traditional firewall. NGFW can filter packets based on applications. NGFWs can detect applications by using *deep packet inspection* and thus can examine the payloads of packets and determine if they are carrying malware. In addition to basic firewall protections, filtering by applications, and deep packet inspection, NGFWs can also perform URL filtering and intrusion prevention services.
- **Unified threat management.** **Unified threat management (UTM)** is a device that combines several security functions. These include packet filtering, antispam, antiphishing, antispyware, encryption, intrusion protection, and web filtering.

NOTE 2

Often a device that performs services beyond that of a NGFW is called a UTM.

Proxy Servers

In general terms, a *proxy* is a person who is authorized to act as the substitute or agent on behalf of another person. For example, a family member who has been granted the power of attorney for a sick relative can make decisions and take actions on behalf of that person as a proxy.

Proxies are also devices used in computer networking. These devices act as substitutes on behalf of the primary device. A **forward proxy** is a computer or an application that intercepts user requests from the internal secure network and then processes the requests on behalf of the user. When an internal endpoint requests a service such as a file or a webpage from an external web server, it normally connects directly to the remote server. In a network using a forward proxy server, the endpoint first connects to the proxy server, which checks its memory to see if a previous request already has been fulfilled and if a copy of that file or page is residing on the proxy server in its temporary storage area (*cache*). If not, the proxy server connects to the external web server using its own IP address (instead of the internal endpoint's address) and requests the service. When the proxy server receives the requested item from the web server, the item is forwarded to the requester.

A **reverse proxy** routes requests coming from an external network to the correct internal server. To the outside user, the IP address of the reverse proxy is the final IP address for requesting services; however, only the reverse proxy can access the internal servers. Forward proxy and reverse proxy servers are illustrated in Figure 9-5.

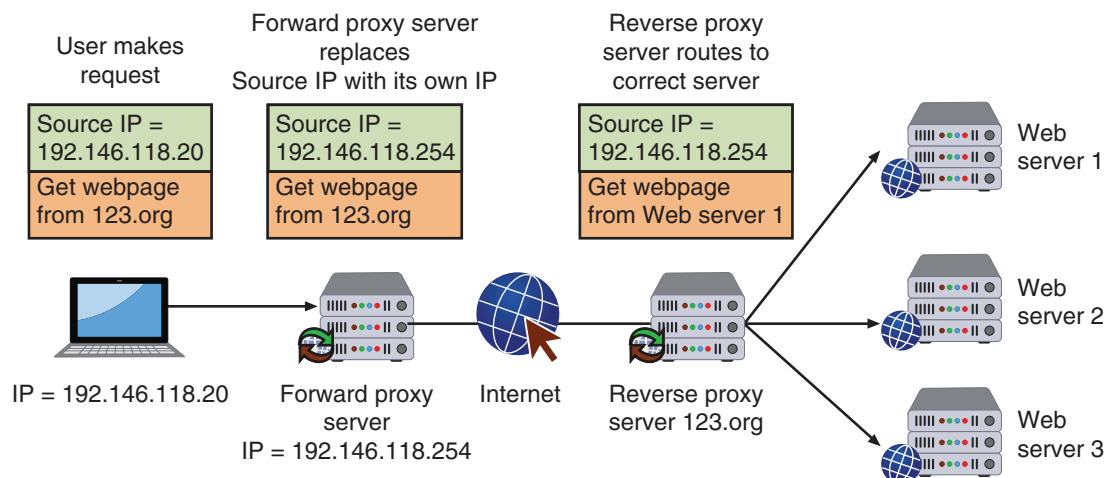


Figure 9-5 Forward and reverse proxy servers

Acting as the intermediary, a proxy server can provide a degree of protection. First, it can look for malware by intercepting it before it reaches the internal endpoint. Second, a proxy server can hide the IP address of endpoints inside the secure network so that only the proxy server's IP address is used on the open Internet.

Deception Instruments

Deception is the act of causing someone to accept as true that is false. Deception can be used as a security defense: by directing threat actors away from a valuable asset to something that has little or no value, threat actors can be tricked into thinking what they are attacking is valuable when it is not, or that their attack is successful when it is not. Creating network deception can involve creating and using honeypots and sinkholes.

NOTE 3

Niccolo Machiavelli, an Italian Renaissance diplomat and philosopher who is often called the father of modern political science, once said, "Never attempt to win by force what can be won by deception."

Honeypots

A **honeypot** is a computer located in an area with limited security that serves as “bait” to threat actors. The honeypot is intentionally configured with security vulnerabilities so that it is open to attacks. Security personnel generally have two goals when using a honeypot:

- **Deflect.** A honeypot can deflect or redirect threat actors’ attention away from legitimate servers by encouraging them to spend their time and energy on the decoy server, distracting their attention from the data on the actual server.
- **Discover.** A honeypot can trick threat actors into revealing their attack techniques. Security experts can then determine if actual production systems could thwart such an attack.

Figure 9-6 shows the results from a honeypot dashboard; it lists attacker probes by time and country.

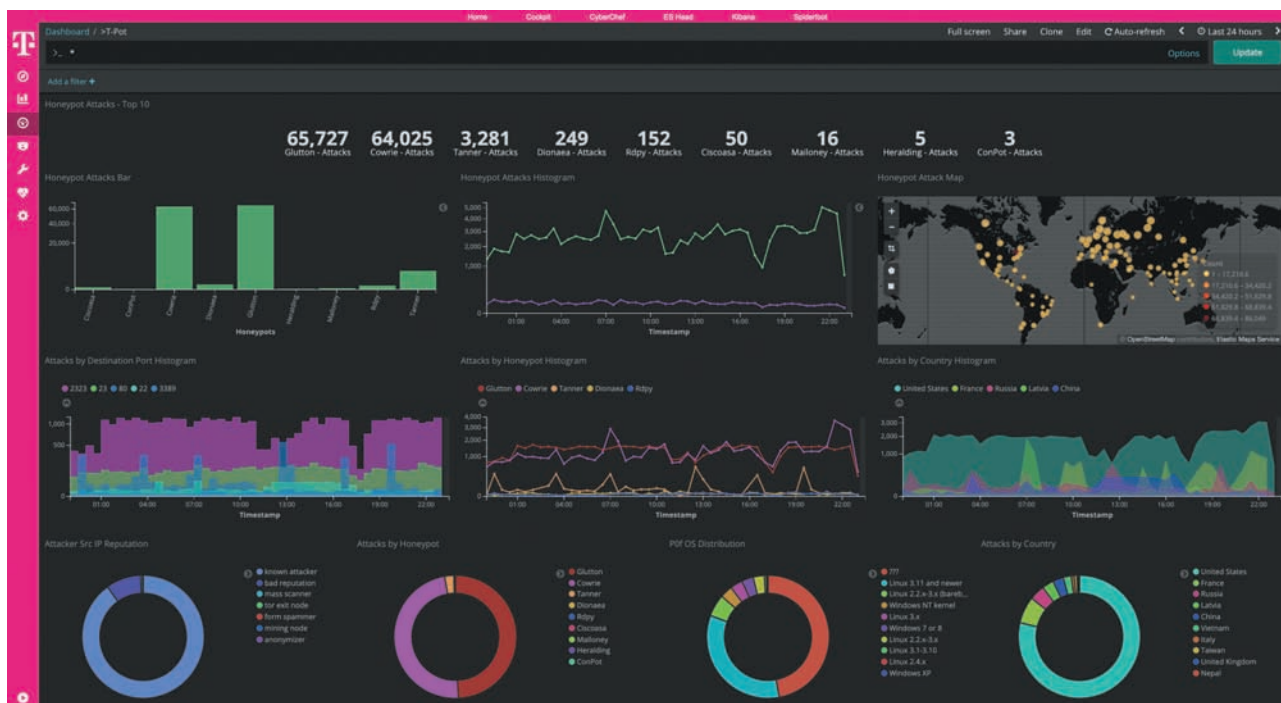


Figure 9-6 Honeypot dashboard

There are different types of honeypots. A *low-interaction honeypot* may only contain a login prompt. This type of honeypot only records login attempts and provides information on the threat actor’s IP address of origin. A *high-interaction honeypot* is designed for capturing much more information from the threat actor. Usually it is configured with a default login and loaded with software, data files that appear to be authentic but are actually imitations of real data files (**honeypfiles**), and **fake telemetry**. (*Telemetry* is the collection of data such as how certain software features are used, application crashes, and general usage statistics and behavior.) A high-interaction honeypot can collect valuable information from threat actors about attack techniques or the particular information they are seeking from the organization.

NOTE 4

The number of attempts against a honeypot is staggering. In one study, 10 honeypots around the world were created to simulate the Secure Shell (SSH) service. One honeypot started receiving login attempts just *52 seconds* after it went online. When all 10 of the honeypots were discovered, a login attempt was made about every *15 seconds on each one*. At the end of one month, over five million attacks had been attempted on the honeypots.¹

Similar to a honeypot, a **honeynet** is a network set up with intentional vulnerabilities. Its purpose is also to invite attacks so that the attacker’s methods can be studied; that information can then be used to increase network security. A honeynet typically contains one or more honeypots.

**CAUTION**

Setting up a honeypot to attract threat actors can be dangerous. There must be no connection between the honeypot and the production network. A safer approach is to use a cloud service provider for setting up a honeypot.

Sinkholes

Another deception technique is to use *sinkholes*. A sinkhole is essentially a “bottomless pit” designed to steer unwanted traffic away from its intended destination to another device, deceiving the threat actor into thinking the attack is successful when the sinkhole is actually providing information about the attack. One type of sinkhole is a **DNS sinkhole**. A DNS sinkhole changes a normal DNS request to a pre-configured IP address that points to a firewall with a rule of *Deny* set for all packets so that every packet is dropped with no return information provided to the sender.

NOTE 5

DNS sinkholes are commonly used to counteract DDoS attacks. Many enterprises contract with a DDoS mitigation service to help identify DDoS traffic and send it to a sinkhole while allowing legitimate traffic to reach its destination. Law enforcement also uses sinkholes to stop a widespread ongoing attack by redirecting traffic away from the attacker’s command and control (C&C) server to a sinkhole. As an added step, the sinkhole can save these packets for further examination in an attempt to identify the threat actors.

Intrusion Detection and Prevention Systems

An *intrusion detection system (IDS)* can detect an attack as it occurs, while an *intrusion prevention system (IPS)* attempts to block the attack. An **inline** system is connected directly to the network and monitors the flow of data as it occurs. A **passive** system is connected to a port on a switch, which receives a copy of network traffic. Table 9-2 lists the differences between inline and passive systems.

Table 9-2 Inline vs. passive IDS

Function	Inline	Passive
Connection	Directly to network	Connected to port on switch
Traffic flow	Routed through the device	Receives copy of traffic
Blocking	Can block attacks	Cannot block attacks
Detection error	May disrupt service	May cause false alarm

In addition, IDS systems can be managed in different ways. *In-band* management is through the network itself by using network protocols and tools, while **out-of-band management** is using an independent and dedicated channel to reach the device.

IDS systems can use different methodologies for monitoring for attacks. In addition, IDS and IPS can be installed on networks as they can on local endpoints.

Monitoring Methodologies

Monitoring involves examining network traffic, activity, transactions, or behavior to detect security-related anomalies. The four monitoring methodologies are anomaly-based monitoring, signature-based monitoring, behavior-based monitoring, and heuristic monitoring.

Anomaly monitoring is designed for detecting statistical anomalies. First, a baseline of normal activities is compiled over time. (A *baseline* is a reference set of data against which operational data is compared.) Whenever activity deviates significantly from the baseline, an alarm is raised. An advantage of this approach is that it can detect the anomalies quickly without trying to first understand the underlying cause. However, normal behavior can change easily and even quickly, so anomaly-based monitoring is subject to false positives. In addition, anomaly-based monitoring can impose heavy processing loads on the systems where they are being used. Finally, because anomaly-based monitoring takes time to create statistical baselines, it can fail to detect events before the baseline is completed.

A second method for auditing usage is to examine network traffic, activity, transactions, or behavior and look for well-known patterns, much like antivirus scanning. This is known as **signature-based monitoring** because it compares activities against a predefined signature. Signature-based monitoring requires access to an updated database of signatures along with a means to actively compare and match current behavior against a collection of signatures. One of the weaknesses of signature-based monitoring is that the signature databases must be constantly updated, and as the number of signatures grows, the behaviors must be compared against an increasingly large number of signatures. Also, if the signature definitions are too specific, signature-based monitoring can miss variations.

Behavioral monitoring attempts to overcome the limitations of both anomaly-based monitoring and signature-based monitoring by being adaptive and proactive instead of reactive. Rather than using statistics or signatures as the standard by which comparisons are made, behavior-based monitoring uses the “normal” processes and actions as the standard. Behavior-based monitoring continuously analyzes the behavior of processes and programs on a system and alerts the user if it detects any abnormal actions, at which point the user can decide whether to allow or block the activity. One advantage of behavior-based monitoring is that it is not necessary to update signature files or compile a baseline of statistical behavior before monitoring can take place. In addition, behavior-based monitoring can more quickly stop new attacks.

The final method takes a completely different approach and does not try to compare actions against previously determined standards (like anomaly-based monitoring and signature-based monitoring) or behavior (like behavior-based monitoring). Instead, it is founded on *experience-based techniques*. Known as **heuristic monitoring**, it attempts to answer the question, *Will this do something harmful if it is allowed to execute?* Heuristic (from the Greek word for *find or discover*) monitoring is like heuristic antivirus detection. However, instead of creating a virtual environment in which to test a threat, IDS heuristic monitoring uses an algorithm to determine if a threat exists. Table 9-3 illustrates how heuristic monitoring could trap an application that attempts to scan ports that the other methods might not catch.

Table 9-3 Methodology comparisons to trap port scanning application

Monitoring methodology	Trap application scanning ports?	Comments
Anomaly-based monitoring	Depends	Only if this application has tried to scan previously and a baseline has been established
Signature-based monitoring	Depends	Only if a signature of scanning by this application has been previously created
Behavior-based monitoring	Depends	Only if this action by the application is different from other applications
Heuristic monitoring	Yes	IDS is triggered if any application tries to scan multiple ports

NOTE 6

A major difference between a NIDS and a NIPS is its location. A NIDS has sensors that monitor the traffic entering and leaving a firewall, and reports back to the central device for analysis. A NIPS, on the other hand, would be located inline on the firewall itself. This allows the NIPS to act more quickly to block an attack.

NOTE 7

HSMs are covered in Module 6.

Network Detection and Prevention Systems IDS and IPS can be applied to networks as well as hosts (endpoints). These network-based systems include the following:

- *Network intrusion detection systems.* A **network intrusion detection system (NIDS)**, similar to a software-based host intrusion detection system (HIDS), watches for attacks on the network. As network traffic moves through the network, NIDS sensors—usually installed on network devices such as firewalls and routers—gather information and report back to a central device.
- *Network intrusion prevention system.* A **network intrusion prevention system (NIPS)** not only monitors to detect malicious activities but also attempts to stop them, much like a host intrusion detection system (HIPS).

Network Hardware Security Modules

A *hardware security module (HSM)* is a removable external cryptographic device. For endpoints, an HSM is typically a USB device, an expansion card, or a device the connects directly to a computer through a port.

However, if many endpoints use an HSM, having a centralized device can improve processing times and increase security. A **network hardware security module** is a special trusted network computer that performs cryptographic operations such as key management, key exchange, onboard random number generation, key storage facility, and accelerated symmetric and asymmetric encryption. Due to the risks associated with a compromised network hardware security module, these are usually built on specialized hardware running a security-focused OS and have limited external access.

Configuration Management

It is essential that these security appliances be properly configured. Not only does a misconfigured device allow threat actors an opening into the network; it also provides a false sense of security that makes it difficult to realize a problem exists (*we've got our NIPS running; that will give us protection*). Basic configuration management tools include the following:

- **Secure baseline configurations.** The purpose of a *baseline* is twofold: it is the initial starting point and the minimum that can be used for comparisons. A secure **baseline configuration** for security appliances likewise has two purposes. First, it is the starting point for configuring a device. While many security appliance configurations go beyond the baseline, the baseline sets the core fundamentals of how the device should be initially configured before the specific configurations are applied. Second, the baseline configuration can be considered the bare minimum: no configuration should be less than the secure baseline configuration.

NOTE 8

Secure baseline configuration documents can be purchased to help organizations define and document what constitutes a hardened and secure system. These configurations can also ensure that the organization is meeting all statutory, regulatory, and contractual requirements.

- **Standard naming conventions.** Using the same conventions for assigning names to appliances (**standard naming conventions**) can eliminate confusion regarding the various appliances. These conventions will vary by organization, but an example is: *“Device names are limited to 15 characters by technical necessity. To ensure interoperability with other systems, only letters and numbers shall be used. Each device name shall have the following minimum structure: the first three characters are the appropriate unit identifier (mandatory); the next six numbers are the device’s inventory control tag number (mandatory); the remaining six characters may be used at the discretion of the department, or not used at all (optional).”*
- **Defined Internet Protocol schema.** An **Internet Protocol schema** is a standard guide for assigning IP addresses to devices. This makes it easier to set up and troubleshoot devices and helps to eliminate overlapping or duplicate subnets and IP address device assignments, avoid unnecessary complexity, and not waste IP address space.
- **Diagrams.** Creating a visual mapping (**diagram**) of security appliances can likewise be valuable when new appliances are added or when troubleshooting is required.

TWO RIGHTS & A WRONG

1. The bypass firewall rule action is designed for media-intensive protocols or traffic from a trusted source.
2. A stateful packet filter looks at packets and permits or denies it based solely on the firewall rules.
3. A forward proxy is a computer or an application program that intercepts user requests from the internal secure network and then processes these requests on behalf of the user.

See Appendix B for the answer.

SECURITY TECHNOLOGIES

CERTIFICATION

2.1 Explain the importance of security concepts in an enterprise environment.

3.3 Given a scenario, implement secure network designs.

In addition to security appliances are general security technologies that can provide a defense. Some of these security technologies can be found in both standard networking devices (such as switches and routers) and specialized security appliances. The categories of these security technologies are access technologies, monitoring and managing technologies, and design technologies.

Access Technologies

Some security technologies are designed to grant or deny access. The access may be to the network or to specific data. These technologies include access control list, virtual private network, network access control, and data loss prevention.

NOTE 9

While a separate security device can provide in-depth protection, it can also slow the flow of data as the data must be sent through the device. A router using an ACL, on the other hand, can operate at the higher speed of the router and not delay network traffic.

Access Control List (ACL)

As its name implies, an **access control list (ACL)** contains rules that administer the availability of digital assets by granting or denying access to the assets. The two types of ACLs include *filesystem ACLs*, which filter access to files and directories on an endpoint by telling the OS who can access the device and what privileges they are allowed. *Networking ACLs* filter access to a network. Network ACLs are often found on routers.

On external routers that face the Internet, router ACLs can restrict known vulnerable protocols from entering the network. They can also be used to limit traffic entering the network from unapproved networks. ACLs can also protect against IP spoofing that imitates another computer's IP address. Because IP spoofing attacks often use

known unused and untrusted addresses, an external router ACL can help block these addresses (usually by designating a range of IP addresses) and thus minimize IP spoofing attacks.



CAUTION

Antispoofing ACLs on external routers require frequent monitoring because the address ranges that are denied can frequently change.

NOTE 10

Software-based VPNs are often used on mobile devices and offer the most flexibility in how network traffic is managed. However, hardware-based VPNs, typically used for site-to-site connections, are more secure, have better performance, and can offer more flexibility.

Router ACLs can also be used on internal routers that process interior network traffic. Internal router ACLs usually are less restrictive but more specific than those on external routers ACLs since the devices on the internal network are generally considered to be friendly. Internal router ACLs are often configured with explicit *allow* and *deny* statements for specific addresses and protocol services. Internal router ACLs can also limit devices on the network from performing IP spoofing by applying outbound ACLs that limit the traffic to known valid local IP addresses.

Virtual Private Network (VPN)

A **virtual private network (VPN)** is a security technology that enables authorized users to use an unsecured public network, such as the Internet, as if it were a secure private network. It does this by encrypting all data transmitted between the remote endpoint and the network, not just specific documents or files. There are two common

types of VPNs. A **remote access VPN** is a user-to-LAN connection for remote users. The second type is a **site-to-site VPN**, in which multiple sites can connect to other sites over the Internet. Some VPNs allow the user to always stay connected instead of connecting and disconnecting from it. These are called **always-on VPNs**.

The two options for using a VPN depend on which traffic needs to be protected. A **full tunnel** sends all traffic to the VPN concentrator and protects it. However, not all traffic—such as web surfing or reading personal email—may need to be protected through a VPN. In this case, a **split tunnel**, or routing only some traffic over the secure VPN while other traffic directly accesses the Internet, may be used instead. Using a split tunnel can help to preserve bandwidth and reduce the load on the VPN concentrator.

Many protocols can be used for VPNs. The most common are IPsec and SSL or the weaker TLS. The **Layer 2 Tunneling Protocol (L2TP)** is a VPN protocol that does not offer encryption or protection, so it is usually paired with IPsec (L2TP/IPsec). The current version of HTML, **HTML 5**, can be used as a “clientless” VPN on an endpoint so that no additional software must be installed. Other popular VPN protocols include OpenVPN, SoftEther, WireGuard, SSTP, and IKEv2/IPsec.

Network Access Control (NAC)

The waiting room at a doctor’s office is an ideal location for the spread of germs. Waiting patients are in a confined space, feel ill, and typically have weakened immune systems. A sick patient in the waiting room could easily infect all other waiting patients. It is not uncommon for a physician to post a nurse at the door of the waiting room to screen patients. Anyone who comes to the waiting room with certain symptoms is denied access (and rescheduled to a special after-hours appointment), given a prescription by the nurse for general medication, or directed to a separate quarantine room away from other patients.

This is the logic behind **network access control (NAC)**. NAC examines the current state of an endpoint before it can connect to the network. Any device that does not meet a specified set of criteria, such as having the most current antivirus signature or the software firewall properly enabled, is denied access to the network, given restricted access to computing resources, or connected to a “quarantine” network where the security deficiencies are corrected, after which the endpoint is connected to the normal network. The goal of NAC is to prevent computers with suboptimal security from potentially infecting other computers through the network.

Some NAC systems use software installed on endpoints (**agents**) to gather information (called a host agent health check). An agent may be a *permanent NAC agent* and reside on end devices until uninstalled, or it may be a *dissolvable NAC agent* that disappears after reporting information to the NAC. Instead of installing agents on each device, the NAC technology can be embedded within a Microsoft Windows Active Directory domain controller. When a device joins the domain and a user logs in, NAC uses Active Directory to scan the device to verify that it complies with the necessary criteria. This is an **agentless** NAC because no additional software is required.

An example of the NAC process is illustrated in Figure 9-7:

1. The client performs a self-assessment using a System Health Agent (SHA) to determine its current security posture.
2. The assessment, known as a Statement of Health (SoH), is sent to a server called the Health Registration Authority (HRA). This server enforces the security policies of the network. It also integrates with other external authorities such as antivirus and patch management servers to retrieve current configuration information.
3. If the client is approved by the HRA, it is issued a Health Certificate.
4. The Health Certificate is then presented to the network servers to verify that the client’s security condition has been approved.
5. If the client is not approved, it is connected to a quarantine network where the deficiencies are corrected, and then the computer is allowed to connect to the network.

NOTE 11

NAC also can be used to ensure that systems not owned by the organization—such as those owned by customers, visitors, and contractors—can be granted access without compromising security.

NOTE 12

NAC uses two methods to direct an infected endpoint away from the normal production network. Interestingly, threat actors also use each method in their attacks. The first method is ARP poisoning and the second is DNS poisoning, each of which is covered in Module 8.

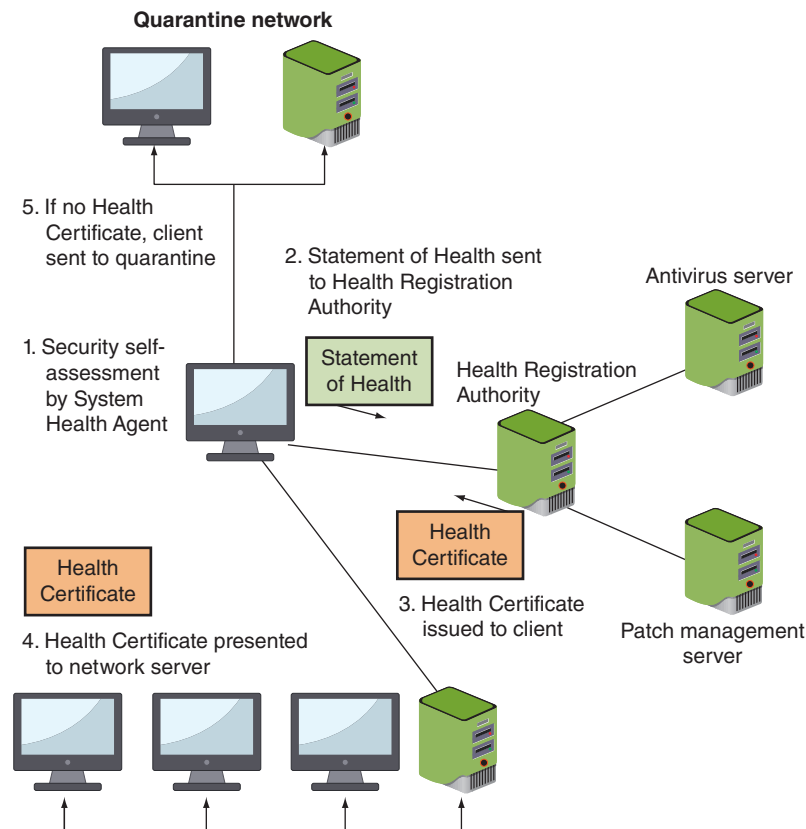


Figure 9-7 Network access control (NAC) process

Data Loss Prevention (DLP)

Keeping corporate data secure is a challenge for all organizations. While the threat of data theft from outside threat actors remains high, increasingly inside employees are careless or make mistakes when handling confidential corporate data. Employee carelessness with data has been identified in two primary areas. First, against company policy, many employees routinely send confidential data to their private email accounts so they can easily access it when needed. About one-third of employees admit to sending corporate data to their personal email accounts up to three times each month. Second, sensitive data is often sent to an approved third-party as an email attachment—but to the wrong recipient. Almost three-fourths of employees admit to sending data to the wrong recipient once per month.²

NOTE 13

Surprisingly, research has shown that security awareness training has not had an impact on employee mishandling of sensitive data. The percentage of employees who admit to sending misdirected emails is the highest in organizations that provide security awareness training most frequently. These same employees are almost twice as likely to send company data to their personal email accounts.

One means of securing internal corporate data is through **data loss prevention (DLP)**. DLP is considered as **rights management**, or the authority of the owner of the data to impose restrictions on its use. DLP is a system of security tools used to recognize and identify data critical to the organization and ensure it is protected. This protection involves monitoring who is using the data and how it is being accessed. Critical or confidential data can be tagged as such. A user who attempts to access the data to disclose it to an unauthorized user will be prevented from doing so.

Most DLP systems use *content inspection*. Content inspection is a security analysis of the transaction within its approved context. Content inspection looks at the security level of the data, who is requesting it, where the data is stored, when it was requested, and where it is going. DLP systems also can use *index matching*. Documents that have been identified as needing protection, such as the program source code for a new software application, are analyzed by the DLP system and complex computations are conducted based on the analysis. Thereafter, if even a small part of that document is leaked, the DLP system can recognize the snippet as being from a protected document.

DLP begins with an administrator creating DLP rules based on the data (what is to be examined) and the policy (what to check for). DLPs can be configured to look for specific data (such as Social Security and credit card numbers), lines of computer software source code, words in a sequence (to prevent a report from leaving the network), maximum file sizes, and file types. In addition, whitelists and blacklists can be created to prevent specific files from being scanned. These rules are then loaded into a DLP server.

When a policy violation is detected by the DLP agent, it is reported back to the DLP server. Different actions can then be taken. These could include blocking the data, redirecting it to an individual who can examine the request, quarantining the data until later, or alerting a supervisor of the request.

In addition to using DLP to protect data, organizations use other techniques as well. Applying encryption can naturally protect the data but may pose barriers for the recipient to decrypt it. When the data is used only for testing purposes, such as determining if a new app functions properly, **masking** may be used. Data masking involves creating a copy of the original data but obfuscating (making unintelligible) any sensitive elements such as a user's name or Social Security number. By replacing the actual information with fictitious information, testing can still be carried out. Similar to masking, **tokenization** obfuscates sensitive data elements, such as an account number, into a random string of characters (*token*). The original sensitive data element and the corresponding token are then stored in a database called a *token vault* so that if the actual data element is needed, it can be retrieved as needed. Unlike encryption, which requires using an algorithm and a key, tokenization can hide the data while making the retrieval process more seamless. Tokenization is illustrated in Figure 9-8.

NOTE 14

One of the drawbacks of DLP is that rules must be continually created and maintained as new employees, third-party agent contractors, and customers are added and new data sets are created. Increasingly, machine learning (ML) is used by DLP to continually create and modify the criteria for protecting data.

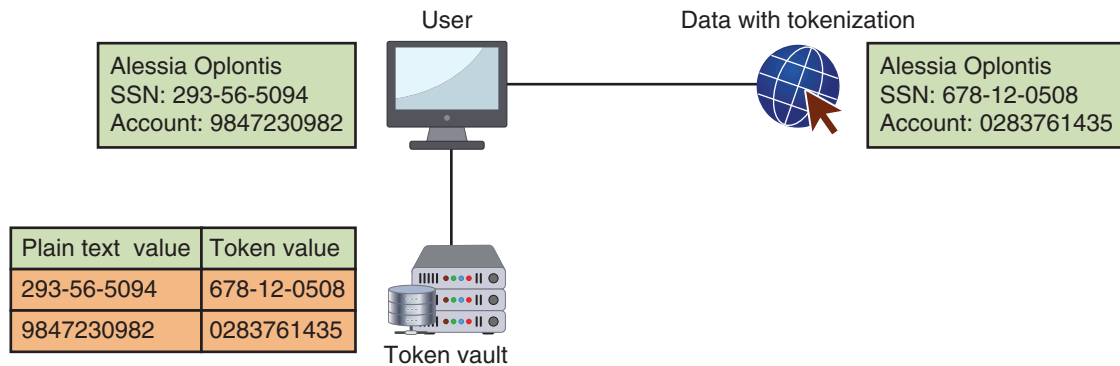


Figure 9-8 Tokenization



CAUTION

Data masking may not always provide strong protection from identifying individuals, even if the user's name or Social Security Number is obfuscated. According to a study of census data, 87 percent of the American population has a unique combination of sex, birth date, and zip code. This means that the combination of these three pieces of information is sufficient to identify a huge portion of the population.

Technologies for Monitoring and Managing

Several security technologies relate to monitoring and managing network resources. These technologies include port security, packet capture and analysis, monitoring services, file integrity monitors, and quality of service.

Port Security

Securing the ports on a network device like a switch or router is essential to securing a network. Threat actors who access a network device through an unprotected port can reconfigure the device to their advantage. This introduces a number of vulnerabilities, one of which is the compromise of **route security** or the trust of packets sent through

a router. False route information can be injected or altered by weak port security that would enable the insertion of individual false route updates or the installation of bogus routers into the routing infrastructure.

In Figure 9-9, computer Alpha, which is connected to Switch A, wants to send frames to computer Beta on Segment 2. Because Switch A does not know where Beta is located, it “floods” the network with the packet (sends it to all destinations). The packet then travels down Segment 1 to Switch B and down Segment 3 to Switch C. Switch B then adds Alpha to its lookup table that it maintains for Segment 1, and Switch C also adds it to its lookup table for Segment 3. Yet if Switch B or C has not yet learned the address for Alpha, they will both flood Segment 2 looking for Beta; that is, each switch will take the packet sent by the other switch and flood it back out again because they still do not know where Beta is located. Switch A then will receive the packet from each segment and flood it back out on the other segment. This *switching loop* causes a *broadcast storm* as the frames are broadcast, received, and rebroadcast by each switch. Broadcast storms can cripple a network in a matter of seconds to the point that no legitimate traffic can occur.

NOTE 15

Because the headers that a Layer 2 switch examines do not have a time to live (TTL) value, a packet could loop through the network indefinitely.

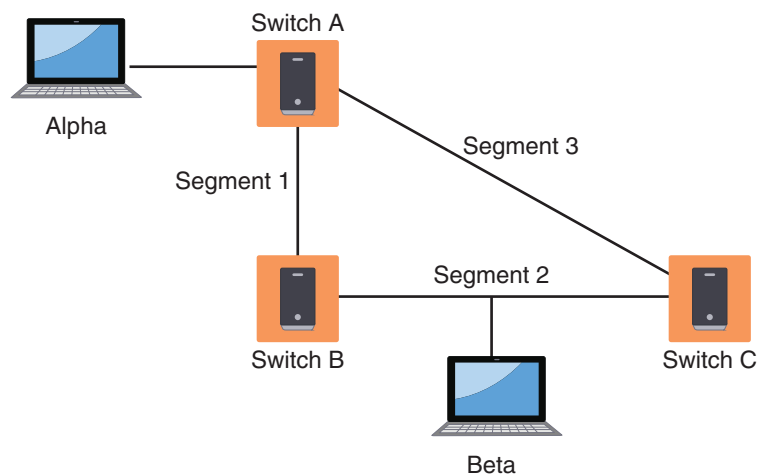


Figure 9-9 Broadcast storm

Broadcast storm prevention can be accomplished by **loop prevention**, which uses the IEEE 802.1d standard *spanning-tree protocol (STP)*. The STP uses an algorithm that creates a hierarchical “tree” layout that spans the entire network. It determines all the redundant paths that a switch has to communicate, recognizes the best path, and then blocks out all other paths. STP does this by sending out *bridge protocol data units (BPDU)* that give information about the switch port (such as MAC address and priority). This enables switches in the STP to share information with other switches. BPDUs are also periodically sent to inform other switches of port changes.

However, threat actors can try to take advantage of the STP by sending out their own malicious BPDUs to the switch to change its configuration. Because BPDUs should only be exchanged between switches, a defense is to enable **BPDU guard**, which is a feature on the switch that creates an alert when a BPDU is received from an endpoint and not a switch. In such an instance, the port on the switch is disabled and no traffic is sent or received by that port.

NOTE 16

DHCP snooping can also prevent users from connecting a consumer-grade router at their desk that also provides DHCP addresses.

A BPDU guard in a switch has similar port security protections. *Dynamic Host Configuration Protocol (DHCP)* is a network management protocol that automates the process of configuring an endpoint on IP networks by dynamically assigning an IP address and other network configuration parameters to endpoints. Threat actors may attempt to connect a DHCP server to the network to offer their own IP address to DHCP clients. A switch with **DHCP snooping** drops any DHCP traffic that the switch determines is unacceptable. It also stores information about the incident for further investigation.

Other port security steps to thwart an attack directed at network devices are summarized in Table 9-4.

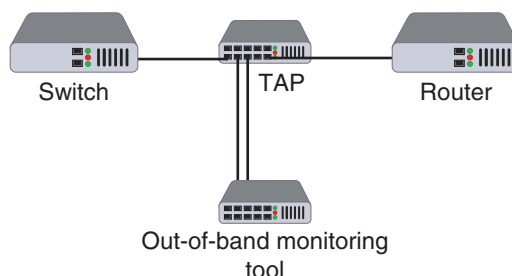
Table 9-4 Thwarting attacks through port security

Type of attack	Description	Port security defense
MAC flooding	An attacker can overflow the switch's address table with fake MAC addresses, forcing it to act like a hub, sending packets to all devices.	Use a switch that can close ports with too many MAC addresses.
MAC address spoofing	If two devices have the same MAC address, a switch may send frames to each device. An attacker can change the MAC address on her device to match the target device's MAC address.	Configure the switch so that only one port can be assigned per MAC address.
ARP poisoning	The attacker sends a forged ARP packet to the source device, substituting the attacker's computer MAC address.	Use an ARP detection appliance.
Unauthorized packet capturing	Attackers connect their device to the switch's port.	Secure the switch in a locked room and close all unused ports on the switch.

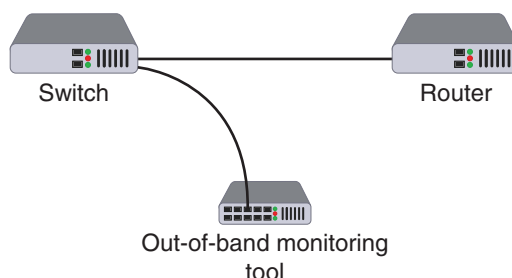
Packet Capture and Analysis

Capturing packets and performing an analysis are critical for understanding the current state of the network. Analyzing packets helps to monitor network performance and reveal cybersecurity incidents.

Monitoring traffic on switches generally can be done in two ways. A separate **port TAP (test access point)** can be installed. A port TAP transmits the send and receive data streams simultaneously on separate dedicated channels so that all data arrives at the monitoring tool in real time. A port TAP is shown in Figure 9-10.

**Figure 9-10** Port TAP

A managed switch on an Ethernet network supports **port mirroring**. Port mirroring is also called **port spanning** because it uses a *Switch Port Analyzer (SPAN)*. Port mirroring allows the administrator to configure the switch to copy (mirror) traffic on some or all ports to a designated monitoring port on the switch. Port mirroring is illustrated in Figure 9-11, where the monitoring tool is connected to the mirror port and can view all network traffic moving through the switch. Port mirroring is designed for “spot checking,” while a TAP is best for high-speed networks that have a large volume of traffic.

**Figure 9-11** Port mirroring

NOTE 17

A TAP device is completely passive: it has no power source or IP or MAC address so that it cannot be attacked. Also, TAPs are “court approved” so that all data captured can be used as evidence in an investigation or trial.

A network TAP is one example of a device that can be placed on a network to gather information. Other devices include **network sensors** to monitor traffic (for network intrusion detection and prevention devices), **collectors** to gather traffic (for SIEM devices), and **aggregators** to combine multiple network connections into a single link.

Monitoring Services

As a supplement to the internal data gathering and analysis of security data, an external third-party **monitoring service** can also be used. These services can provide additional resources to assist an organization in its cybersecurity defenses, such as processing cybersecurity data on managed SIEM platforms and continuously updating and applying rules to detect attacks.

File Integrity Monitors

File integrity monitors are based on a technology designed to “keep an eye on” files to detect any changes within the files that may indicate a cyberattack. After establishing a baseline for “clean” files, a file integrity monitor examines files to see if they have changed, when the change occurred, how they changed, who changed them, and what can be done to restore those files if the changes are unauthorized.

File integrity monitors are used for detecting malware as well as maintaining compliance with industry-specific regulations. The Payment Card Industry Data Security Standard (PCI DSS) has no less than four requirements related to file integrity monitors. The PCI DSS Requirement 10.5.5 states that organizations in compliance will “Use file integrity monitoring or change detection software on logs to ensure that existing log data cannot be changed without generating alerts (although new data being added should not cause an alert).”

NOTE 18

PCI DSS is covered in Module 2.

The problem with file integrity monitors is the high volume of “noise,” or too much unhelpful information. Files may change frequently for many benign reasons with limited insight into whether a change poses a security risk. While file integrity monitors can be beneficial, they need to provide sufficient insight so that proper actions can be taken.

Quality of Service (QoS)

Modern networks have many types of traffic, all sharing the same bandwidth. However, not all network traffic is the same: a critical video conference call could be sharing the same bandwidth as someone downloading a huge movie file on the same network (in violation of company policy) so that each are competing for the same bandwidth. This often results in packet loss for the video conference call as well as delay and jitter, all of which affects the quality of the call.

Quality of Service (QoS) is a set of network technologies used to guarantee its ability to dependably serve network resources and high-priority applications to endpoints. QoS technologies provide “differentiated” handling and capacity allocation to specific network traffic. A network administrator can assign the order in which packets are handled and the amount of bandwidth given to an application or traffic flow (called traffic shaping).

The first step in QoS is that traffic must be classified or differentiated using QoS tools. Classifying traffic according to the corporate policy allows organizations to ensure the consistency and adequacy of network resources for the most important applications. While traffic can be prioritized by port or IP address, doing so has obvious limitations. (It is unlikely that a specific IP address should always have high network capacity, no matter what activity is being performed.) Instead, traffic should be viewed by the application or user, which can then result in a more meaningful classification of the data.

Almost all firewalls today recognize QoS settings. (They do so through configuring the “Type of Service” eight-bit field within an IP packet that is reserved for QoS markings.) However, some firewalls do not have this level of granularity but still provide QoS by defining “Low,” “Medium,” “High,” and “Guaranteed” ratings to different types of traffic.

Design Technologies

Technologies that relate to the secure design of the network include network segmentation and load balancing.

Network Segmentation

Understanding network segmentation involves first knowing the principle of zero trust. Examples of network segmentation include virtual LANs and a demilitarized zone.

Zero Trust Several principles govern network segmentation. One principle is **zero trust**. Zero trust is a strategic initiative about networks that is designed to prevent successful attacks. As its name implies, zero trust attempts to eliminate the concept of trust from an organization's network architecture.

Many networks are based on a traditional security model that operates on the assumption that everything inside an organization's network should be trusted. This is now considered an outdated and broken trust model because it is assumed that a user's identity has not been compromised and that all users will act responsibly and thus can be trusted.

The zero-trust model recognizes instead that trust is a vulnerability. Once on the network, users can freely move laterally to access or exfiltrate data. Because most networks have already been compromised and threat actors are "lurking in the shadows," malicious attackers likewise can freely move through the network.

There are several steps in creating a zero-trust network architecture:

1. Identify a "protect surface" that is made up of the network's most critical and valuable data, assets, applications, and services. Because it contains only data most critical to an organization's operations, the protect surface is much smaller than the network itself.
2. Determine the entities that interact with the protect surface. This includes determining how traffic moves across the organization in relation to it. **East-west traffic** is the movement of data from one server to another server within a data center. (In contrast, *north-south traffic* describes endpoint-to-server traffic that moves between the data center and an unsecured location outside of the data center network.) Besides understanding traffic across the protect surface, this step involves knowing who the users are that access it, which applications they are using, and how they are connecting to it.
3. Put controls in place as close to the protect surface as possible. This is seen as creating a "microperimeter" around it that "moves" with the protect surface as it grows. A microperimeter is often created by deploying a NGFW to ensure only known and allowed traffic or legitimate applications have access to the protect surface.

Virtual LANs (VLANs) Zero trust requires that networks be segmented. This can be accomplished by using switches to divide the network into a hierarchy. *Core switches* reside at the top of the hierarchy and carry traffic between switches, while *workgroup switches* are connected directly to the devices on the network. It is often beneficial to group similar users together, such as all the members of the Accounting Department. However, grouping by user can be difficult because all users might not be in the same location and served by the same switch.

It is possible to segment a network by separating devices into logical groups. This is known as creating a **virtual LAN (VLAN)**. A VLAN allows scattered users to be logically grouped together even though they are physically attached to different switches. This can reduce network traffic and provide a degree of security. VLANs can be isolated so that sensitive data is transported only to members of the VLAN.

VLAN communication can take place in two ways. If multiple devices in the same VLAN are connected to the same switch, the switch itself can handle the transfer of packets to the members of the VLAN group. However, if VLAN members on one switch need to communicate with members connected to another switch, a special "tagging" protocol must be used, either a proprietary protocol or the vendor-neutral IEEE 802.1Q. These special protocols add a field to the packet that "tags" it as belonging to the VLAN.

NOTE 19

Zero trust is not designed to make a system trusted but, instead, to eliminate trust. The motto of zero trust is "Never trust; always verify."

NOTE 20

Core switches must work faster than workgroup switches because core switches must handle the traffic of several workgroup switches.

NOTE 21

Although network subnetting and VLANs are often considered to be similar, they do have differences. Subnets are subdivisions of IP address classes (Class A, B, or C) and allow a single Class A, B, or C network to be used instead of multiple networks. VLANs are devices that are connected logically rather than physically, either through the port they are connected to or by their MAC address.

NOTE 22

Another security advantage of VLANs is that they can be used to prevent direct communication between servers, which can bypass firewall or IDS inspection. Servers that are placed in separate VLANs will require that any traffic headed toward the default gateway for inter-VLAN routing be inspected.

Demilitarized Zone (DMZ) Imagine a bank that located its automated teller machine (ATM) in the middle of their vault. This would be an open invitation for disaster by inviting every outside user to enter the secure vault to access the ATM. Instead, the ATM and the vault should be separated so that the ATM is in a public area that anyone can access, while the vault is restricted to trusted individuals. In a similar fashion, locating public-facing servers such as web and email servers inside the secure network is also unwise. An attacker must only break out of the security of the server to access the secure network.

NOTE 23

DMZs were first introduced in Module 8 concerning physical security controls.

To allow untrusted outside users access to resources such as web servers, most networks employ a *demilitarized zone (DMZ)*. The DMZ functions as a separate network that rests outside the secure network perimeter: untrusted outside users can access the DMZ but cannot enter the secure network.

Consider Figure 9-4 (shown earlier), which illustrates a DMZ containing a web server and an email server that are accessed by outside users. In this configuration, a single firewall with three network interfaces is used: the link to the Internet is on the first network interface, the DMZ is formed from the second network interface, and the secure internal LAN is based on the third network interface. However, this makes the firewall device a single point of failure for the network. It also must take care of all the traffic to the DMZ and internal network. A more secure approach is to have two firewalls, as seen in Figure 9-12. In this configuration, an attacker would have to breach two separate firewalls to reach the secure internal LAN.

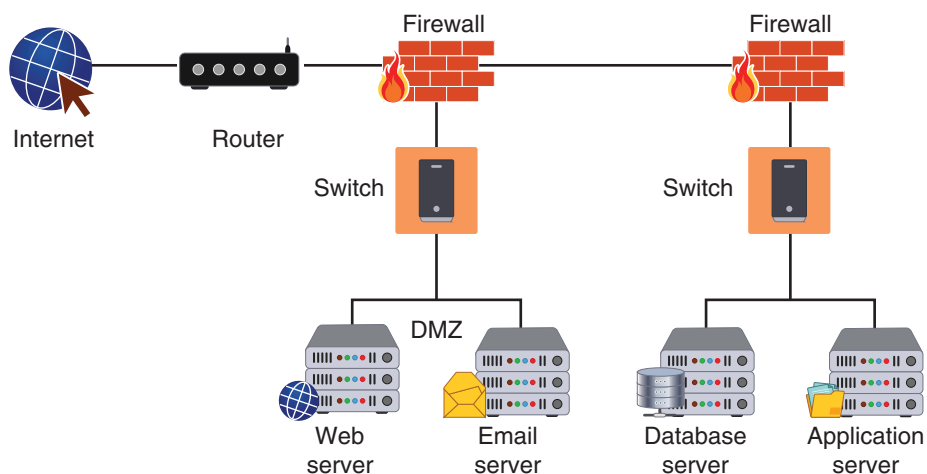


Figure 9-12 DMZ with two firewalls

CAUTION

Some consumer routers advertise support to configure a DMZ. However, this is not a DMZ. Rather, the feature allows only one local device to be exposed to the Internet for Internet gaming or videoconferencing by forwarding all the ports at the same time to that one device.

How should a DMZ be configured so that trusted administrators can still access the hardware and software in a DMZ? If a pathway is enabled for administrators to enter the zone, that same pathway, if compromised, can provide access to threat actors back to the secure network.

A common approach is to use a **jump box** (sometimes called a *jump server* or *jump host*), as shown in Figure 9-13. A jump box is a minimally configured administrator server (either physical or virtual) within the DMZ. Running only essential protocols and ports, it connects two dissimilar security zones while providing tightly restricted access between them. An administrator accesses the jump box, which is connected to the administrative interface of the devices within the DMZ.

CAUTION

To further limit the vulnerabilities of a jump box, administrators should ensure that all jump box software is regularly updated, limit the programs that can run on a jump box, implement multifactor authentication for logins, do not allow outbound access or severely restrict access from the jump box, and use ACLs to restrict access to specific authorized users.

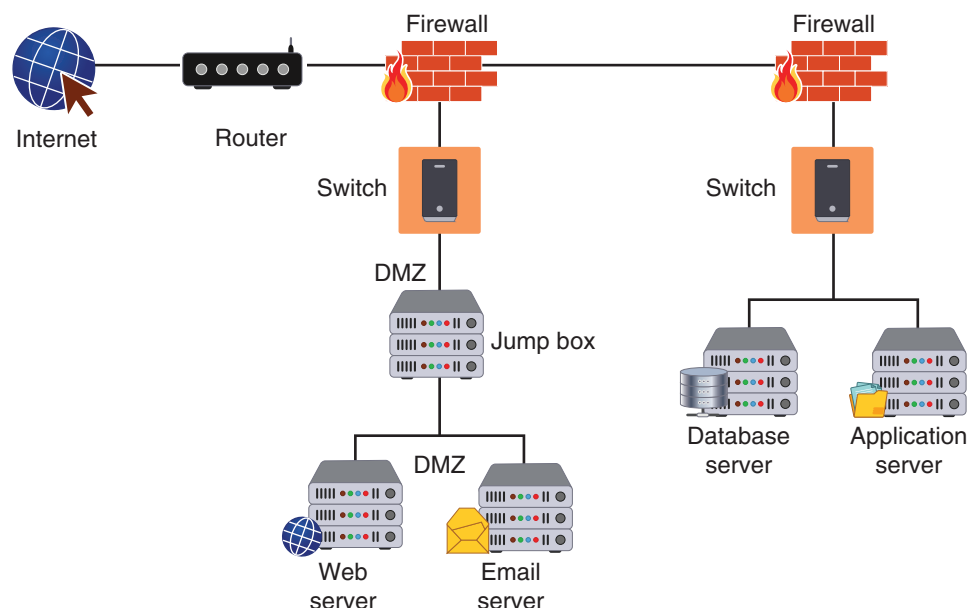


Figure 9-13 Jump box

In recent years, an additional security configuration has been used to limit risks when administering a DMZ. Instead of an administrator connecting to a jump box from any computer, only a dedicated *secure admin workstation (SAW)* can be used to connect to the jump box. Using a SAW prevents an administrator's infected computer from compromising the jump box.

Other zones can also be used for security. These are listed in Table 9-5.

Table 9-5 Other network zones

Name	Description	Security benefits
Intranet	A private network that belongs to an organization that can only be accessed by approved internal users	Closed to the outside public, thus data is less vulnerable to external threat actors
Extranet	A private network that can also be accessed by authorized external customers, vendors, and partners	Can provide enhanced security for outside users compared to a publicly accessible website
Guest network	A separate open network that anyone can access without prior authorization	Permits access to general network resources like web surfing without using the secure network

Load Balancing

Load balancing is a technology that can help to evenly distribute work across a network. Requests that are received can be allocated across multiple devices such as servers. To the user, this distribution is transparent and appears as if a single server is providing the resources. Load-balancing technology reduces the probability of overloading a single server and ensures that each networked server benefits from having optimized bandwidth. Load balancing can be performed either through software running on a computer or as a dedicated hardware device known as a *load balancer*.

Different **scheduling** protocols are used in load balancers. In a *round-robin* scheduling protocol, the rotation applies to all devices equally. A scheduling protocol that distributes the load based on which devices can handle the load more efficiently is known as *affinity* scheduling. Affinity scheduling may be based on which load balancers have the least number of connections at a given point in time.

When multiple load balancers are used together to achieve *high efficiency (H/A)*, they can be placed in different configurations. In an **active-passive** configuration, the primary load balancer distributes the network traffic to the most suitable server, while the secondary load balancer operates in a "listening mode." This second load balancer constantly monitors the performance of the primary load balancer and will step in and take over the load-balancing duties should the primary load balancer start to experience difficulties or fail. The active-passive configuration allows

NOTE 24

Load balancers in an active-active configuration can also remember previous requests from users and retain this information. If the user returns and requests the same information, the user is directed to the load balancer that previously served the request, and the information can be immediately provided.

for uninterrupted service and can also handle planned or unplanned service outages. In an **active-active** configuration, all load balancers are always active. Network traffic is combined, and the load balancers then work together as a team.

The servers behind load balancers are often given a **virtual IP (VIP)** address. As its name suggests, this is not an actual IP address. Instead, it is an IP address and a specific port number that can be used to reference physical servers. A VIP with the address and port `172.32.250.1:80` can be configured to accept one type of traffic, while the VIP `172.32.250.1:443` can accept another type of traffic. Multiple VIPs can be created using the same IP address as long as a different port number is used.

Load balancing can also support session **persistence**, a process in which a load balancer creates a link between an endpoint and a specific network server for the duration of a session. This can help improve the user experience and optimize network resource usage.

Using a load balancer has security advantages. Because load balancers generally are located between routers and servers, they can detect and stop attacks directed at a server or application. A load balancer can also detect and prevent protocol attacks that could cripple a single server. Some load balancers can hide HTTP error pages or remove server identification headers from HTTP responses, denying attackers additional information about the internal network.

TWO RIGHTS & A WRONG

1. There are two types of ACLs: filesystem ACLs filter access to files and directories on an endpoint, and networking ACLs filter access to a network. Network ACLs are often found on routers.
2. The Layer 2 Tunneling Protocol (L2TP) is a VPN protocol that does not offer any encryption or protection, so it is usually paired with IPsec.
3. Tokenization is used for creating test data.

See Appendix B for the answer.



VM LAB

You're now ready to complete the live, virtual machine labs for this module. The labs can be found in the Practice It folder in each MindTap module.

SUMMARY

- Today, networks have both standard networking devices and specialized security appliances. Security can be achieved by using security appliances that directly address security and by using the security features found in standard networking devices. Using both standard networking devices and security appliances can result in a layered security approach, which can significantly improve security.
- A computer firewall is designed to limit the spread of malware. A firewall uses bidirectional inspection to examine outgoing and incoming network packets, allowing approved packets to pass through but taking different actions when it detects a suspicious packet. The actions are based on specific criteria or rules. Older firewalls often processed each rule as a separate instruction in sequence, while modern firewalls allow a priority order. In addition to filtering based on packets, firewalls can also apply content/URL filtering.
- Stateless packet filtering on a firewall looks at a packet and permits or denies it based solely on the firewall rules. Stateful packet filtering uses both the firewall rules and the state of the connection. Open source firewalls are freely available; other firewalls are owned by an entity that has an exclusive right to them and are called proprietary firewalls. A software firewall runs as a program or service on a device, such as a computer or router. Hardware firewalls are specialized separate devices that inspect traffic. A host-based firewall is a

software firewall that runs on and protects a single endpoint device (a host). An appliance firewall is typically a separate hardware device designed to protect an entire network. A virtual firewall is one that runs in the cloud.

- There are several specialized firewall appliances. A web application firewall (WAF) looks at applications using HTTP. A network address translation gateway is a cloud-based technology that performs NAT translations for cloud services. A next generation firewall (NGFW) has additional functionality beyond a traditional firewall. Unified threat management (UTM) is a device that combines several security functions. These include packet filtering, antispam, antiphishing, antispysware, encryption, intrusion protection, and web filtering.
- A forward proxy is a computer or an application program that intercepts user requests from the internal secure network and then processes these requests on behalf of the user. A reverse proxy routes requests coming from an external network to the correct internal server. Acting as the intermediary, a proxy server can provide a degree of protection.
- A honeypot is a computer located in an area with limited security that serves as “bait” to threat actors. The honeypot is intentionally configured with security vulnerabilities so that it is open to attacks. A high-interaction honeypot is usually configured with a default login and loaded with software, data files that appear to be authentic but are actually imitations of real data files called honeyfiles, and fake telemetry data. A honeynet is a network set up with intentional vulnerabilities. A sinkhole is essentially a “bottomless pit” designed to steer unwanted traffic away from its intended destination to another device. One type of sinkhole is a DNS sinkhole.
- An intrusion detection system (IDS) can detect an attack as it occurs, while an intrusion prevention system (IPS) attempts to block the attack. An inline system is connected directly to the network and monitors the flow of data as it occurs. A passive system is connected to a port on a switch, which receives a copy of network traffic. Monitoring involves examining network traffic, activity, transactions, or behavior to detect security-related anomalies. The four monitoring methodologies are anomaly-based monitoring, signature-based monitoring, behavior-based monitoring, and heuristic monitoring. A network intrusion detection system (NIDS), similar to a software-based host intrusion detection system (HIDS), watches for attacks on the network. A network intrusion prevention system (NIPS) not only monitors to detect malicious activities but also attempts to stop them.
- A network hardware security module is a special trusted network computer that performs cryptographic operations such as key management, key exchange, onboard random number generation, key storage facility, and accelerated symmetric and asymmetric encryption. These security appliances must be properly configured. Not only does a misconfigured device allow threat actors an opening into the network, it also provides a false sense of security that makes it difficult to realize the problem.
- An access control list (ACL) contains rules that administer the availability of digital assets by granting or denying access to the assets. On external routers that face the Internet, router ACLs can restrict known vulnerable protocols from entering the network. Router ACLs can also be used on internal routers that process interior network traffic. These router ACLs usually are less restrictive but more specific than those on external routers ACLs since the devices on the internal network are generally considered to be friendly. A virtual private network (VPN) is a security technology that enables authorized users to use an unsecured public network, such as the Internet, as if it were a secure private network. It does this by encrypting all data that is transmitted between the remote endpoint and the network.
- Network access control (NAC) examines the current state of an endpoint before it can connect to the network. Any device that does not meet a specified set of criteria, such as having the most current antivirus signature or the software firewall properly enabled, is denied access to the network, given restricted access to computing resources, or connected to a “quarantine” network where the security deficiencies are corrected. Some NAC systems use software installed on endpoints (agents), while other systems are agentless and do not require additional software to be installed.
- Data loss prevention (DLP) is a system of security tools used to recognize and identify data critical to the organization and ensure that it is protected. This protection involves monitoring who is using the data and how it is being accessed. Data that is considered critical to the organization or is confidential can be tagged as such. A user who attempts to access the data to disclose it to an unauthorized user will be prevented from doing so. In addition to using DLP to protect data, masking may be used. Data masking involves creating a copy of the original data but obfuscates (makes unintelligible) any sensitive elements such as a user’s name or Social Security number. By replacing the actual information with fictitious information, the testing can still be carried out. Similar to masking, tokenization obfuscates sensitive data elements, such as an account number, into a random

string of characters (token). The original sensitive data element and the corresponding token are then stored in a database called a token vault so that if the actual data element is needed, it can be retired as needed.

- Broadcast storm prevention can be accomplished by loop prevention, which uses the IEEE 802.1d standard spanning-tree protocol (STP). The STP uses an algorithm that creates a hierarchical “tree” layout that “spans” the entire network. It determines all the redundant paths that a switch has to communicate, recognizes the best path, and then blocks all other paths. STP sends out bridge protocol data units (BPDUs) that give information about the switch port to enable switches in the STP to share information with other switches. A threat actor can try to take advantage of the STP by sending out their own malicious BPDUs to the switch to change its configuration. Such an attack can be thwarted by a BPDU guard, which is a feature on the switch that creates an alert when a BPDU is received from an endpoint and not a switch.
- Monitoring traffic on switches generally can be done in two ways. A separate port TAP (test access point) can be installed. A TAP transmits the send and receive data streams simultaneously on separate dedicated channels so that all data arrives at the monitoring tool in real time. A managed switch on an Ethernet network supports port mirroring, also called port spanning. Port mirroring allows the administrator to configure the switch to copy (mirror) traffic that occurs on some or all ports to a designated monitoring port on the switch. As a supplement to the internal data gathering and analysis of security data, an external third-party monitoring service can also be used. File integrity monitors are based on a technology designed to “keep an eye on” files to detect any changes within the files that may indicate a cyberattack. After establishing a baseline for “clean” files, a file integrity monitor examines files to see if they have changed, when the change occurred, how they changed, who changed them, and what can be done to restore those files if the changes are unauthorized. Quality of Service (QoS) is a set of network technologies used to guarantee a network’s ability to dependably serve resources and high-priority applications to endpoints. Almost all firewalls today recognize QoS settings. Load balancing is a technology that can help to evenly distribute work across a network.

Key Terms

access control list (ACL)	hardware firewall	out-of-band management
active-active	heuristic monitoring	passive
active-passive	honeyfiles	persistence
agentless	honeynet	port mirroring (port spanning)
agents	honeypot	port TAP (test access point)
aggregators	host-based firewall	proprietary firewall
always-on VPN	HTML 5	Quality of Service (QoS)
anomaly monitoring	inline	remote access VPN
appliance firewall	Internet Protocol schema	reverse proxy
baseline configuration	intranet	rights management
behavioral monitoring	jump box	route security
BPDU guard	Layer 2 Tunneling Protocol (L2TP)	scheduling
broadcast storm prevention	load balancing	signature-based monitoring
collectors	loop prevention	site-to-site VPN
content/URL filtering	masking	software firewall
data loss prevention (DLP)	monitoring service	split tunneling
DHCP snooping	network access control (NAC)	standard naming conventions
diagram	network address translation gateway	stateful packet filtering
DNS sinkhole	network hardware security module	stateless packet filtering
east-west traffic	network intrusion detection system (NIDS)	tokenization
extranet	network intrusion prevention system (NIPS)	unified threat management (UTM)
fake telemetry	network sensors	virtual firewall
file integrity monitors	next generation firewall (NGFW)	virtual IP (VIP)
firewall	open source firewall	virtual LAN (VLAN)
forward proxy		virtual private network (VPN)
full tunnel		web application firewall
geographical consideration		zero trust

Review Questions

1. Which of the following is NOT a firewall rule parameter?
 - a. Visibility
 - b. Time
 - c. Context
 - d. Action
2. Which firewall rule action implicitly denies all other traffic unless explicitly allowed?
 - a. Force Allow
 - b. Force Deny
 - c. Bypass
 - d. Allow
3. Leah is researching information on firewalls. She needs a firewall that allows for more generic statements instead of creating specific rules. What type of firewall should Leah consider purchasing that supports her need?
 - a. Content/URL filtering firewall
 - b. Policy-based firewall
 - c. Hardware firewall
 - d. Proprietary firewall
4. Emilie is reviewing a log file of a new firewall. She notes that the log indicates packets are being dropped for incoming packets for which the internal endpoint did not initially create the request. What kind of firewall is this?
 - a. Stateful packet filtering
 - b. Connection-aware firewall
 - c. Proxy firewall
 - d. Packet filtering firewall
5. What is a virtual firewall?
 - a. A firewall that runs in the cloud
 - b. A firewall that runs in an endpoint virtual machine
 - c. A firewall that blocks only incoming traffic
 - d. A firewall appliance that runs on a LAN
6. Which of these appliances provides the broadest protection by combining several security functions?
 - a. NAT
 - b. WAF
 - c. UTM
 - d. NGFW
7. Which of the following contains honeyfiles and fake telemetry?
 - a. High-interaction honeypot
 - b. Attacker-interaction honeypot
 - c. Honeypotnet
 - d. Honeyserver
8. Maja has been asked to investigate DDoS mitigations. Which of the following should Maja consider?
 - a. DDoS Prevention System (DPS)
 - b. DNS sinkhole
 - c. MAC pit
 - d. IP denier
9. Which type of monitoring methodology looks for statistical deviations from a baseline?
 - a. Behavioral monitoring
 - b. Signature-based monitoring
 - c. Anomaly monitoring
 - d. Heuristic monitoring
10. Which statement regarding a demilitarized zone (DMZ) is NOT true?
 - a. It can be configured to have one or two firewalls.
 - b. It typically includes an email or web server.
 - c. It provides an extra degree of security.
 - d. It contains servers that are used only by internal network users.
11. Which of the following functions does a network hardware security module NOT perform?
 - a. Fingerprint authentication
 - b. Key management
 - c. Key exchange
 - d. Random number generator
12. Which of these is NOT used in scheduling a load balancer?
 - a. The IP address of the destination packet
 - b. Data within the application message itself
 - c. Round-robin
 - d. Affinity
13. In which of the following configurations are all the load balancers always active?
 - a. Active-active
 - b. Active-passive
 - c. Passive-active-passive
 - d. Active-load-passive-load
14. Which device intercepts internal user requests and then processes those requests on behalf of the users?
 - a. Forward proxy server
 - b. Reverse proxy server
 - c. Host detection server
 - d. Intrusion prevention device

15. Sofie needs to configure the VPN to preserve bandwidth. Which configuration would she choose?
 - a. Narrow tunnel
 - b. Split tunnel
 - c. Full tunnel
 - d. Wide tunnel
16. Which of the following is not a basic configuration management tool?
 - a. Baseline configuration
 - b. Standard naming convention
 - c. Diagrams
 - d. MAC address schema
17. Which of the following is NOT correct about L2TP?
 - a. It is used as a VPN protocol.
 - b. It must be used on HTML 5 compliant devices.
 - c. It does not offer encryption.
 - d. It is paired with IPsec.
18. Which of the following is NOT a NAC option when it detects a vulnerable endpoint?
 - a. Deny access to the network.
 - b. Give restricted access to the network.
 - c. Update Active Directory to indicate the device is vulnerable.
 - d. Connect to a quarantine network.
19. Hanna has received a request for a data set of actual data for testing a new app that is being developed. She does not want the sensitive elements of the data to be exposed. What technology should she use?
 - a. Masking
 - b. Tokenization
 - c. Data Object Obfuscation (DOO)
 - d. PII Hiding
20. How does BPDU guard provide protection?
 - a. It detects when a BPDU is received from an endpoint.
 - b. It sends BPDU updates to all routers.
 - c. BPDUs are encrypted so that attackers cannot see their contents.
 - d. All firewalls are configured to let BPDUs pass to the external network.

Hands-On Projects



CAUTION

If you are concerned about installing any of the software in these projects on your regular computer, you can instead use the Windows Sandbox or install the software in the Windows virtual machine created in the Module 1 Hands-On Projects. Software installed within the virtual machine will not impact the host computer.

Project 9-1: Using GlassWire Firewall

Time Required: 25 minutes

Objective: Given a scenario, implement secure network designs.

Description: GlassWire is a firewall and Security and Information Event Management (SIEM) product. In this activity, you will download and install GlassWire.

1. Use your web browser to go to **www.glasswire.com**. (If you are no longer able to access the site through the URL, use a search engine to search for "GlassWire.")
2. Click **Features** and scroll through the page to read about the different features and configuration options in this product.
3. Click **FREE DOWNLOAD** and then click **DOWNLOAD GLASSWIRE** to download the file.
4. Navigate to the location of the downloaded file **GlassWireSetup.exe** and launch this program to install GlassWire by accepting the default settings.
5. Click **Finish** to run GlassWire.
6. Note that the information scrolls horizontally to the left regarding events that are occurring. Open a web browser and surf the Internet for several minutes.
7. Return to GlassWire.
8. Slide the scroller at the bottom of the screen to consolidate the views.
9. Click **Apps**. What information is given in the left pane? How can this be useful?
10. Click **Traffic** to view an analysis of the different traffic types.

11. Open a web browser, and then arrange the GlassWire window and the browser window side by side on your computer screen.
12. Use your web browser to surf the web, and watch the GlassWire screen as well. What can you learn from this?
13. Close the browser window and maximize GlassWire.
14. Click the **Firewall** button. What apps or services have recently gone through your firewall?
15. Click the **Usage** button to see a summary of the local Apps utilized, the Hosts accessed, and the Traffic Type.
16. Click **Alerts**. Scroll through any alerts that have been issued. What can you tell about them?
17. How valuable is this information from GlassWire?
18. Close all windows.

Project 9-2: Configuring Microsoft Windows Defender Firewall—Apps

Time Required: 20 minutes

Objective: Given a scenario, implement secure network designs.

Description: In this project, you explore configuration settings on Windows Firewall for allowing an app to penetrate the firewall.

NOTE 25

Windows Firewall uses three different profiles: domain (when the computer is connected to a Windows domain), private (when connected to a private network, such as a work or home network), and public (used when connected to a public network, such as a public Wi-Fi). A computer may use multiple profiles so that a business laptop computer may use the domain profile at work, the private profile when connected to the home network, and the public profile when connected to a public Wi-Fi network. Windows asks whether a network is public or private when you first connect to it.

1. Click **Start** and then **Settings**.
2. Click **Update & Security**.
3. Click **Windows Security**.
4. Click **Firewall & network protection**.
5. Click **Allow an app through firewall**. Depending upon your network configuration, click the type of network that says **(active)**.
6. The Microsoft Windows Defender host-based firewall is application-centric: users can create an opening in the firewall for each specific application. This is more secure than permanently opening a port in the firewall that will always remain open as opposed to a port that is only opened when the application requires it and is then closed. However, there is an issue with these types of firewalls in that installed apps routinely give themselves permissions through the firewall without making that clear to the user. Scroll down through the apps that have access through the firewall. Does this lengthy list surprise you? What are the security risks?
7. Click **Microsoft Lync**.
8. Click **Details**.
9. Click **Network Types** and read through the options. Why would an app be approved for one type but not the other?
10. Click **Cancel**.
11. Click **What are the risks of unblocking an app?** What type of information is provided? How helpful is this information? How could it be improved?
12. Close the browser window.
13. Click **Cancel**.
14. Now add an app that can penetrate the firewall. Click **Allow another app**.
15. See the apps that have been installed on this computer by clicking **Browse**.
16. Scroll down and select an app and click **Open**.
17. Click **Network Types**. For this app, which network type would you select? Why?
18. Click **Cancel**.
19. Click **Cancel** on the **Add an app** window.
20. Click **Cancel** on the **Allow apps to communicate through Windows Defender Firewall**.
21. Close all windows.

Project 9-3: Configuring Microsoft Windows Defender Firewall—Ports

Time Required: 20 minutes

Objective: Given a scenario, implement secure network designs.

Description: In this project, you explore configuration settings on Windows Firewall for opening a port on the firewall.

1. Click **Start** and then **Settings**.
2. Click **Update & Security**.
3. Click **Windows Security**.
4. Click **Firewall & network protection**.
5. Click **Advanced settings**.
6. In the **Windows Defender Firewall with Advanced Security** window, click **Inbound Rules** in the left pane. Expand the screen so you can see all of the columns.
7. Why do some apps have **Any** for **Protocol**, **Local Port**, and **Remote Port** while other apps are more restrictive for these parameters?
8. Click **Outbound Rules** and view the same parameters.
9. Create a specific rule to open a firewall port. Click **Outbound Rules** in the left pane.
10. In the right pane, notice the different ways in which a firewall filter can be created. What is the advantage of **Filter by Profile**?
11. Click **New Rule**.
12. Note that there are four types of rules that can be created. Click **Custom** and then **Next**.
13. A custom rule can apply to all programs, a specific program, or a Windows service. Click **Customize** next to **Services**.
14. Click **Apply to this service** and scroll through the list of available services.
15. Click **Cancel**.
16. Be sure that **All programs** is selected, and click **Next**.
17. Specific ports and protocols can be selected for this rule. Under **Protocol type**, select **TCP**. Note the **Protocol number** is automatically selected.
18. In **Local port**, select **Specific Ports**.
19. Enter **80**.
20. In **Remote port**, select **All ports**, if necessary.
21. Click **Next**.
22. Under **Which local IP addresses does this rule apply to?** click **These IP addresses**.
23. Click **Add**.
24. Click **This IP address range**.
25. In **From**, enter **192.168.0.0**.
26. In **To**, enter **192.168.0.255** and click **OK**.
27. Click **Next**.
28. Read through the three options for actions. Be sure that **Block the connection** is selected. Click **Next**.
29. Read through the three options for when this rule applies. Click **Next**.
30. A name can be given to this rule. However, click the back button and review each of the settings that were created for this rule. What type of rule have you just created? What will it block? Why?
31. Click **Cancel** and close all windows.

Case Projects

Case Project 9-1: Data Loss Prevention Comparison

Research at least four different data loss prevention (DLP) products from four different vendors. Create a table that compares at least six different functions and options. Based on your research, which would you choose? What features make this product the optimum? Why? Write a short paragraph that summarizes your research.

Case Project 9-2: Cloud-Based Honeypots

Research cloud-based honeypots. What are their advantages? What are their disadvantages? When should they not be used? How could one be set up? Create a one-page paper of your research.

Case Project 9-3: Hardening a Jump Box

How should a jump box be configured? Create a list of configurations that you would use to set up a jump box that had the fewest risks.

Case Project 9-4: Researching Network Access Control

Use the Internet to research the network access control products from Microsoft and Cisco. How are they different? How are they similar? What are some of the options for each product? Which would you choose, and why? Write a one-page paper on your research.

Case Project 9-5: UTM Comparison

Create a table of four UTM devices available today. Include the vendor name, pricing, a list of features, the type of protections it provides, etc. Based on your research, assign a value of 1–5 (from lowest to highest ranking) that you would give that UTM. Include a short explanation of why you gave it that ranking.

Case Project 9-6: Zero Trust

Use the Internet to research zero trust. What is it? What are its advantages? What are its disadvantages? What technologies does it require? Is it a long-term security solution? Is it widely accepted? What do you think about it? Write a one-page paper on your research.

Case Project 9-7: Network Firewall Comparison

Use the Internet to identify three network firewalls and create a chart that compares their features. Note if they are rule based or policy based, perform stateless or stateful packet filtering, what additional features they include (IDS, content filtering, etc.), their costs, etc. Which would you recommend? Why?

Case Project 9-8: Community Site Activity

The Information Security Community Site is an online companion to this textbook. It contains a wide variety of tools, information, discussion boards, and other features to assist learners. Go to **community.cengage.com/infosec2** and click the *Join or Sign in* icon to log in, using your login name and password that you created in Module 1. Click **Forums (Discussion)** and click on **Security+ Case Projects (7th edition)**. Read the following case study.

Some schools and libraries use Internet content filters to prohibit users from accessing undesirable websites. These filters are designed to protect individuals, but some claim it is a violation of their freedom. What are your opinions about Internet content filters? Do they provide protection for users or are they a hindrance? Who should be responsible for determining which sites are appropriate and which are inappropriate? And what punishments should be enacted against individuals who circumvent these filters? Visit the Community Site discussion board and post how you feel about Internet content filters.

Case Project 9-9: North Ridge Security

North Ridge Security provides security consulting and assurance services. You have recently been hired as an intern to assist them.

Believe It's Magic (BIM) is a regional hair salon with retail outlets in major cities. Because the company was the victim of several recent attacks, BIM wants to completely change its network infrastructure. Currently, the company has a small IT staff, so they have contracted with North Ridge to make recommendations and install the new equipment. First,

however, they have asked North Ridge to give a presentation to their executive staff about the current state of network security defenses.

1. Create a PowerPoint presentation for the executive staff about network security appliances. Include firewalls, proxy servers, IDS and IPS, and network hardware security modules. Your presentation should contain at least 10 slides.
2. One of the BIM's executives has heard about honeypots and has decided BIM should install it to, in his words, "punish those attackers." North Ridge has advised BIM that the purpose of a honeypot is not retaliation, but the executive has been difficult to persuade. However, he saw your presentation and was impressed with your knowledge. North Ridge has asked you to create a memo about deception instruments and why it could be risky and unnecessary for BIM to install those devices. Create a memo that outlines the advantages and disadvantages of deception instruments, and give your recommendation.

References

1. Boddy, Matt, "Exposed: Cyberattacks on cloud honeypots," *Sophos*, Apr. 9, 2019, accessed Jun. 5, 2019, www.sophos.com/en-us/press-office/press-releases/2019/04/cybercriminals-attack-cloud-server-honeypot-within-52-seconds.aspx.
2. "The state of data loss prevention 2020: What you need to know," *Tessian*, May 28, 2020, accessed Jun. 26, 2020, www.tessian.com/blog/the-state-of-data-loss-prevention-2020-what-you-need-to-know/.